network

MDPI

Article

Agentic AI-Driven SOC-as-a-Service for Optimizing Incident Response in Cloud Environments: A Conceptual Framework

Abdulaziz Y. Alhumaidi [1], Faisal A. Al-Qadda [1], Albandari Alsumayt [1,*] and Majid Alshammari [2]

[1] Saudi Aramco Cybersecurity Chair, Networks and Communications Department, College of Computer Science and Information Technology, Imam Abdulrahman Bin Faisal University, Dammam 31441, Saudi Arabia; 2260500212@iau.edu.sa (A.Y.A.); 2260500209@iau.edu.sa (F.A.A.-Q.)
[2] Department of Information Technology, College of Computers and Information Technology, Taif University, Taif 21944, Saudi Arabia; m.alshammari@tu.edu.sa
* Correspondence: afaalsumayt@iau.edu.sa

Abstract

Cloud security operations must process high-volume, rapidly changing telemetry within short response windows while maintaining governance and accountability. However, the literature on cloud defense, SOC modernization, retrieval-augmented generation (RAG), and Agentic AI remains fragmented. This paper combines a legacy corpus of 23 studies with a reproducible Scopus update of 10 quality-appraised studies and proposes a secure Agentic AI-driven SOC-as-a-Service (SOCaaS) framework. The review identifies long-standing problems of alert fatigue, limited operational context, fragmented tooling, and weak validation, together with unresolved concerns regarding trust, explainability, bounded autonomy, forensic preparedness, and prompt injection. The principal technical contribution is a six-layer architecture supported by a cross-cutting security and trust-enforcement plane that separates untrusted telemetry from agent instructions, constrains retrieval and tool use, applies deterministic governance checks, requires human approval for high-impact actions, and enables auditable execution. Four simulation experiments evaluate component-level behavior for automated triage, retrieval grounding, governance-gated orchestration, and audit completeness. Under the stated synthetic assumptions, the governed agentic configuration yields a 6.8-fold reduction in mean response time relative to the modeled manual baseline. These results indicate internal feasibility rather than production efficacy.

Keywords: cloud computing security; SOC-as-a-Service; security operations center; incident response; Agentic AI; cloud governance; systematic literature review; retrieval-augmented generation; SIEM; SOAR

Check for updates

Academic Editors: Ali Khoshkholghi and Purav Shah

Received: 13 July 2026
Revised: 7 September 2026
Accepted: 21 September 2026
Published: 1 October 2026

Copyright: © 2026 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the Creative Commons Attribution (CC BY) license.

1. Introduction

Cloud computing has become a standard component of digital infrastructure because of its scalability, elasticity, cost efficiency, and rapid provisioning. At the same time, the migration of workloads, identities, applications, and sensitive data to public, multi-cloud, and hybrid environments has expanded the attack surface and placed greater strain on security controls. The resulting challenges are not purely technical; they also arise from governance gaps, complex compliance requirements, heterogeneous provider controls, and the difficulty of aligning cloud-native operations with formal frameworks such as the NIST Cybersecurity Framework [1,2]. The shared-responsibility model, provider heterogeneity, and the need for continuous detection, response, and recovery further complicate security operations in highly dynamic environments [1–4].

Security Operations Centers (SOCs), Security Information and Event Management (SIEM) platforms, and Security Orchestration, Automation, and Response (SOAR) capabilities have become central to cyber defense, and their adoption has accelerated alongside the growth of cloud computing. However, long-standing problems persist and remain well documented: alert fatigue, analyst overload, staffing shortages, false positives, limited tool integration, and slow response times [5–10]. These problems are particularly acute in cloud environments, where telemetry volumes are substantial, assets are short lived, infrastructure is API-reachable, and operational decisions must frequently be made within very short windows. This has motivated a shift toward more responsive, integrated, and context-aware security operations that combine monitoring, triage, orchestration, investigation, and controlled response rather than relying on isolated tools or static rules [5,7–12].

AI has therefore become an important field of research in cloud security and cybersecurity. Emerging trends include machine-learning-based threat detection, deep-learning-based classification, LLM-assisted security analysis, retrieval-augmented generation (RAG) for contextual support, and agentic architectures that support goal-directed reasoning, tool use, and multistep coordination [5,13–15]. Implementation-oriented studies further suggest that these capabilities can improve the timeliness, scalability, and contextual awareness of cloud-based security operations [3,12,16–18].

Despite this potential, major questions remain concerning trust, explainability, validation, adversarial robustness, privacy, accountability, and the appropriate balance between human authority and machine autonomy [6,9–11,14,15,19]. Research on trusted autonomy and human–AI collaboration indicates that uncontrolled automation is not an appropriate foundation for cyber defense. Operational systems must instead be transparent, constrained, auditable, and aligned with organizational policy, particularly when cloud response actions can affect business-critical workloads and regulated data.

Agentic security systems introduce an additional attack surface, because they process telemetry, retrieved documents, analyst input, and tool responses that may have been influenced by external parties. An adversary can embed malicious content in a log message, alert field, resource name, ticket, or external intelligence record, causing the agent to interpret the content as an instruction. Such direct or indirect prompt injection can distort reasoning, poison the retrieval context, trigger unauthorized tool calls, or leak sensitive information. Recent benchmark, attack, and defense studies show that instructions can propagate indirectly between agents and that static defenses remain vulnerable to adaptive attacks [20–25]. A sound architecture must therefore separate instructions from evidence, verify provenance, constrain retrieval and tool use, and keep authorization outside the generative model.

The body of literature divides into several overlapping areas: cloud security and standards, cloud incident detection and response, cloud SOC/SIEM/SOAR operations, and the emerging work on agentic and AI-enhanced cybersecurity. In addition, research on interconnected environments, such as IoT-based SOC services and network assurance, indicates that orchestration, control validation, and expert-informed decision support are critical to robust operations [26–28]. However, relatively little research integrates these strands into a coherent cloud-centric account that connects governance, detection, incident response, SOC modernization, and Agentic AI.

This gap motivates the present systematic review of cloud governance, incident response, SOC architecture, automation, and Agentic AI. The combined evidence set of 33 studies is synthesized to identify design patterns, governance issues, adversarial threats, evidence-maturity gaps, and trade-offs relevant to cloud-based SOCaaS. The synthesis then informs a conceptual architecture for cloud incident response that is trustworthy, policy-aware, and auditable.

2. Research Objectives and Questions

The purpose of this study is to consolidate the existing evidence on cloud security operations and Agentic AI, analyze the architectural and governance gaps in cloud security, and develop a secure, auditable, and human-led SOCaaS framework. The review is guided by the following questions:

- RQ1: What concerns does the recent literature identify regarding the operational and governance aspects of cloud computing security?
- RQ2: How are AI, LLM, RAG, and Agentic AI approaches used in cloud-based detection, triage, orchestration, and incident-response workflows involving SOC, SIEM, and SOAR environments?
- RQ3: What trust, explainability, governance, and forensic-readiness issues arise from using Agentic AI in cloud security operations?
- RQ4: How can architectural patterns and design principles contribute to a robust Agentic AI model for SOCaaS in cloud environments?
- RQ5: What controls are required to mitigate prompt injection, retrieval poisoning, unauthorized tool use, and cross-tenant information leakage when Agentic AI processes untrusted security telemetry?

The literature synthesis and the architectural design both address these research questions. The simulation experiments examine specific component-level behaviors under stated assumptions and are not intended as production validation of an end-to-end Agentic AI system.

This paper makes five key contributions: **first**, it consolidates a dispersed literature spanning cloud security, SOC modernization, SIEM/SOAR operations, and adversarial security; **second**, it applies a multidimensional relevance rubric to compare heterogeneous studies; **third**, it identifies recurring architectural, operational, governance, and adversarial-security themes in intelligent automation for cloud security operations; **fourth**, it proposes an Agentic AI-driven SOCaaS framework that integrates telemetry ingestion, automated triage, retrieval-supported reasoning, bounded orchestration, deterministic policy enforcement, human oversight, and auditable response workflows; and **fifth**, it evaluates selected framework components through four seeded simulation experiments that quantify triage suppression, lexical retrieval gain, the speed–control trade-off at the governance threshold, and audit completeness under synthetic assumptions.

This paper is organized as follows. Section 2 states the research objectives and questions. Section 3 presents the review design, including the search strategy, eligibility criteria, study selection, relevance rubric, and thematic synthesis. Section 4 reports the comparative results of the selected studies and identifies recurring patterns in the literature, together with a critical discussion of operational, architectural, and governance trends. Section 5 presents the proposed Agentic AI-driven SOCaaS framework and an illustrative cloud incident-response workflow. Section 6 evaluates the selected framework components through simulations. Section 7 sets out the limitations and future research directions, and Section 8 concludes the paper.

3. Methodology

3.1. Review Design and PRISMA Alignment

This study uses a two-phase focused systematic literature review to examine cloud security governance, incident detection and response, SOC architecture, SIEM/SOAR automation, retrieval-supported analysis, and agentic or semi-autonomous security operations. Phase 1 is the 23-study legacy corpus used to develop the initial synthesis. Phase 2 is a reproducible Scopus update performed to broaden coverage and directly address

agent and RAG security. Phase 2 is reported according to the principal stages of PRISMA 2020: identification, deduplication, screening, retrieval, eligibility assessment, and inclusion. The combined synthesis contains 33 non-duplicate studies. The conceptual synthesis is complemented by component-level simulation experiments described separately in Section 6.

The included studies differ in publication type, technical maturity, research design, validation depth, and subject matter [1–19,26–29]. Consequently, statistical meta-analysis would not provide a meaningful common effect estimate. A qualitative thematic synthesis was therefore used to compare architectural patterns, operational functions, governance controls, adversarial-security concerns, and evidence maturity. The review protocol was not prospectively registered, which is acknowledged as a limitation.

3.2. Information Sources and Search Strategy

Phase 1 used IEEE Xplore and Google Scholar. Searches combined three concept groups: cloud security, operational security, and intelligent automation. The principal logic was "cloud security" OR "cloud incident response", combined with "security operations center" OR SOCaaS OR SIEM OR SOAR, and "agentic AI" OR "AI agent" OR LLM OR "retrieval-augmented generation" OR RAG. Supplementary terms included Wazuh, cloud incident management, trusted autonomy, explainability, auditability, and human oversight.

Phase 2 searched Scopus using four query families covering (S1) Agentic AI with SOC/SIEM/SOAR, (S2) cloud incident response with AI or LLMs, (S3) cybersecurity RAG, and (S4) prompt injection, retrieval poisoning, and agent security. The exports contained 2181 records. DOI- and normalized-title deduplication removed 70 duplicate instances, leaving 2111 records for screening. Document-type restrictions excluded 202 records, and title/abstract screening excluded 1838 records as outside the operational cloud/SOC scope, insufficiently direct, or lacking a relevant AI, agentic, or RAG contribution. A stricter scope check excluded six further records, leaving 65 reports sought for retrieval. Ten reports were retrieved and assessed in full; 55 could not be retrieved through the available institutional or open-access routes. All 10 retrieved reports met the eligibility and quality thresholds and were added to the synthesis. Web of Science Core Collection was not searched and remains a coverage limitation.

3.3. Eligibility Criteria

Studies were included when they satisfied all general eligibility requirements and addressed at least one central technical theme. The general requirements were full-text availability, direct relevance to operational cybersecurity, and sufficient methodological, empirical, or architectural detail to support extraction. Eligible studies also had to address at least one of the following themes:

1. addressed cloud computing security, cloud incident detection, cloud incident response, or cloud security governance;
2. examined SOC, SIEM, SOAR, or SOCaaS in relation to operational cybersecurity;
3. proposed, implemented, evaluated, or reviewed AI, ML, LLM, RAG, or agentic approaches for security monitoring, triage, investigation, orchestration, or response;
4. provided architectural, conceptual, or implementation-oriented contributions relevant to intelligent cloud security operations;
5. were available in full text and contained sufficient methodological or conceptual detail to support extraction and analysis.

Studies were excluded if they focused on non-security uses of AI, lacked operational or architectural relevance, provided insufficient technical detail, duplicated another record, or had been superseded by a more complete version. Peer-reviewed journal and conference papers were preferred. Preprints were retained only where they addressed rapidly emerging subjects for which no equivalent peer-reviewed version was identified. Publication status was considered when interpreting evidence maturity and is a source of potential bias in the final corpus.

3.4. Screening and Study Selection

Study selection followed identification, de-duplication, title/abstract screening, retrieval, and full-text eligibility assessment. The legacy phase contributed 23 studies. The Scopus update contributed 10 additional, non-duplicate studies, producing a combined synthesis of 33 studies.

Intermediate counts for the legacy phase were not preserved and therefore cannot be reconstructed without invention. In contrast, the Scopus update retains database provenance, duplicate counts, title/abstract decisions, exclusion reasons, retrieval status, and quality appraisal. Its PRISMA accounting is: 2181 records identified; 70 duplicates removed; 2111 records screened; 2046 records excluded before retrieval; 65 reports sought; 55 reports not retrieved; 10 full texts assessed; no full-text exclusions; and 10 studies included. These counts describe Phase 2 only and are not presented as retrospective counts for Phase 1.

Figure 1 presents the reproducible flow for the Scopus update. The diagram is intentionally separated from the legacy corpus because its missing intermediate records cannot be reconstructed reliably.

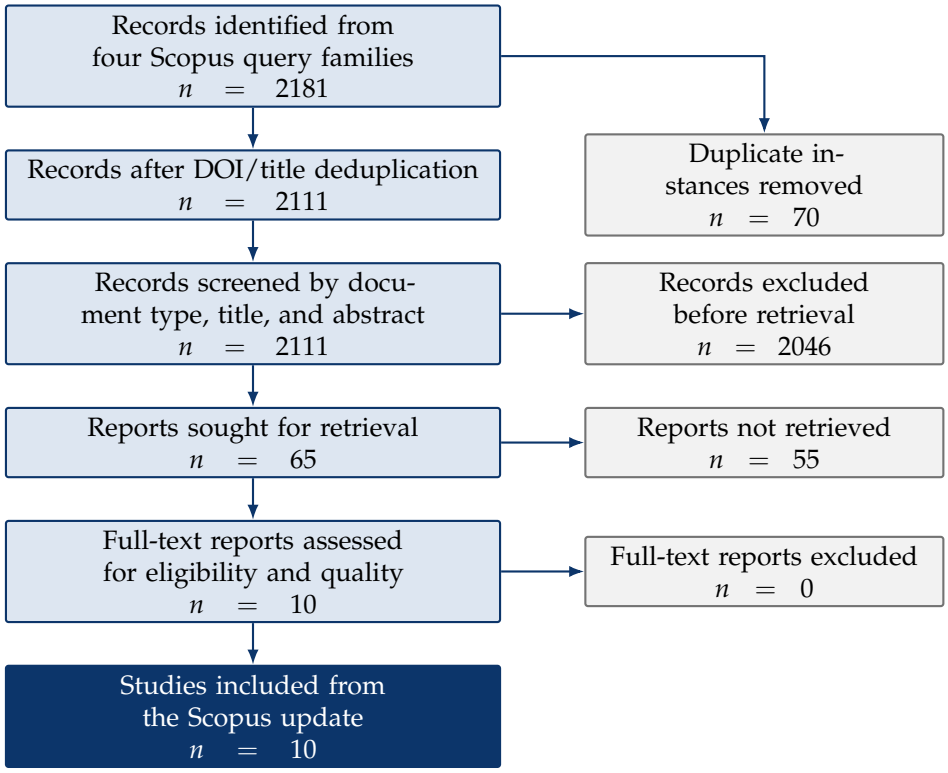


Figure 1. PRISMA-style flow diagram for the reproducible Scopus update (Phase 2). Counts for the 23-study legacy phase are not merged into this diagram because its intermediate screening records were unavailable.

3.5. Quality and Relevance Appraisal

To support consistent comparison, the included studies were appraised across the following dimensions:

- **Agent autonomy**: the extent to which the study addressed autonomous, semi-autonomous, agentic, or tool-using AI behavior;
- **SOC/incident-response alignment**: the degree of connection to operational security monitoring, triage, investigation, or response workflows;
- **Cloud context**: whether the study explicitly addressed cloud environments, cloud platforms, or cloud-related security challenges;
- **Governance and explainability**: the treatment of trust, transparency, policy control, accountability, or explainable decision support;
- **Forensic preparedness**: the presence of auditability, traceability, evidence preservation, or investigation support;
- **Architectural contribution**: the extent to which the study proposed, analyzed, or clarified an operational framework, implementation pattern, or architectural model;
- **Validation maturity**: whether the contribution was conceptual, simulation-based, laboratory-tested, or evaluated in an operational environment;
- **Publication maturity**: whether the source was peer-reviewed or remained a preprint at the time represented in the corpus.

Each relevance dimension was interpreted on a three-level ordinal scale: 0 indicated that the issue was not addressed, 1 indicated limited or indirect treatment, and 2 indicated explicit and substantial treatment. For the Scopus update, full-text quality was additionally assessed on five 0–2 criteria: clarity of aim, reproducibility of method, adequacy of evidence or evaluation, reporting of limitations or threats to validity, and direct relevance to the research questions. A total of 7/10 was required for inclusion. Nine update studies were rated high quality (9–10), and one was rated moderate quality (7); none was excluded at full text. The appraisal was used to characterize evidence maturity and does not make heterogeneous effect estimates directly comparable.

3.6. Data Extraction

A structured framework was used to extract bibliographic information, publication type and year, research objective, cloud setting, SOC function, AI or automation method, retrieval technique, autonomy level, tool-use capability, architectural contribution, governance and human oversight, audit and forensic support, validation method, principal findings, limitations, and future work. Prompt injection, retrieval poisoning, input provenance, tenant isolation, and tool authorization were also treated as extraction fields when they were explicitly discussed. Their limited treatment in the included corpus is reported as a research gap rather than interpreted as proof that a particular implementation lacks those controls.

The extraction process supported comparison across heterogeneous study types, including surveys, systematic reviews, framework papers, conceptual analyses, implementation studies, and conference papers. Structured extraction enabled consistent comparison without imposing the same empirical requirements on fundamentally different research designs.

3.7. Data Synthesis

Because the included studies vary considerably in aims, methods, validation approach, and technical scope, a meaningful statistical meta-analysis was not possible; thematic analysis was therefore adopted. The synthesis was structured and organized around emergent themes, convergent architectural practices, and unresolved tensions in the literature.

The synthesis employed a hybrid coding strategy guided by the research questions and refined through repeated comparison across studies during analysis. Themes included telemetry and monitoring, triage and enrichment, retrieval-supported contextualization, agentic orchestration, human oversight, governance and explainability, adversarial context manipulation, tool authorization, auditability, forensic preparedness, and validation maturity. This approach enabled comparison of architectural and governance evidence without assuming the equivalence of conceptually different validation methods.

Comparative categorization complemented the qualitative synthesis. Studies were grouped according to cloud specificity, governance awareness, detection and orchestration orientation, open-source operational tooling, and agentic or semi-autonomous strategies.

3.8. Replicability and Data Availability

The Scopus exports, deduplicated master record, screening decisions, exclusion reasons, retrieval ledger, full-text candidate list, and quality-appraisal matrix were retained as review artefacts. The synthesis uses 33 studies: 23 from the legacy phase and 10 added after full-text assessment in the Scopus update. No proprietary operational or human-subject data were used. The retained review artifacts permit independent checking of Phase 2, subject to journal supplementary-material requirements; the absence of equivalent intermediate records for Phase 1 remains explicitly reported.

3.9. Ethical Considerations

This research did not involve human participants, patients, animals, or an intervention; therefore, institutional review board approval and informed consent were not required.

During the preparation of this work, the authors used a generative AI assistant (Claude Fable 5.1, Anthropic) to support drafting and organization of the manuscript and to assist in developing the simulation code for Section 6. The authors reviewed, verified, and edited all content, including independent verification of all reported numerical results against the simulation outputs, and remain responsible for study selection, data extraction, analysis, interpretation, source verification, and the final content. No source was accepted solely because it was generated or suggested by an AI system, and AI assistance did not replace scholarly judgment.

4. Systematic Review Results and Discussion

This section presents the comparative results of the combined 33-study synthesis. The analysis highlights convergence, divergence, maturity, and limitations across cloud security, SOC operations, RAG, governance, and agent security. The Scopus update strengthens the evidence on multitenant SOCaaS, operational LLM limits, cloud retrieval, and adversarial testing [20–25,30–33].

4.1. Distribution of Themes Across the Reviewed Literature

The chosen articles can be grouped into four broad and overlapping research streams. The first is the literature on cloud security, governance, and standards, which locates operational and policy issues in securing cloud infrastructures. The second stream covers cloud-specific incident detection, response, and automated incident management in cloud environments [3,4]. The third stream includes SOC, SIEM, SOAR, and SOCaaS research concerned with operational automation, analyst workload, orchestration, and open-source security operations [5,7–12,18,28]. The fourth stream unites AI-enhanced, RAG-supported, and agentic cybersecurity research, in which machine learning, LLMs, tool-using processes, and semi-autonomous strategies are discussed as ways to enhance cyber protection.

Figure 2 summarizes the four overlapping research streams represented in the reviewed literature.

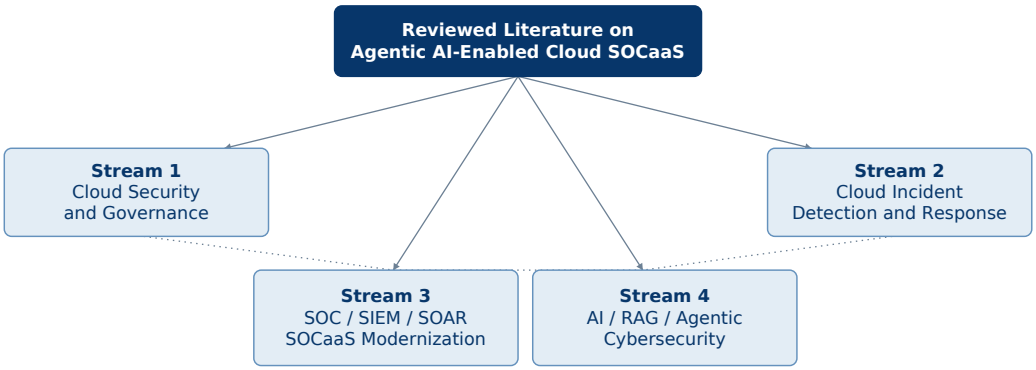


Figure 2. High-level classification of the reviewed literature. The selected studies span four overlapping streams: cloud security and governance (Stream 1) [1,2]; cloud incident detection and response (Stream 2) [3,4]; SOC modernization (Stream 3) [5,7–12,18,28]; and AI/RAG/agentic cybersecurity (Stream 4) [6,13–17,19,29].

These streams are conceptually related, but relatively few studies integrate them comprehensively. Many papers address only one or two dimensions of the problem. Some studies discuss cloud security without considering SOC workflow modernization [1,2], and others examine AI in cybersecurity without addressing the operational challenges of cloud governance or cloud-specific constraints [13–15]. A smaller number are more integrative and more closely aligned with the aim of this paper, namely to connect cloud security operations, cloud automation, AI support, and response orchestration [3,4,10–12,16,17]. This confirms an active but fragmented field that lacks a cloud-centered conceptual synthesis.

4.2. Cloud Security Challenges Framed in the Literature

A recurring observation across the reviewed studies is that cloud environments present security challenges that differ from those of traditional, more centralized infrastructures. Large-scale telemetry, distributed assets, API-driven control planes, rapid service deployment, shared-responsibility models, and the difficulty of applying uniform controls across heterogeneous platforms are repeatedly identified in the literature [1–4]. The challenges these conditions create for security teams are typically high velocity and highly contextual, and they involve governance, compliance, and availability risks.

The review also shows that cloud security problems are not confined to technical detection. Several studies frame them as operational and governance problems concerning policy enforcement, limited visibility, audit requirements, inconsistent controls, and the practicality of aligning cloud-native operations with formal frameworks such as NIST [1,2]. This broader perspective matters because it implies that cloud security cannot be achieved through isolated detection tools alone. It instead requires the coordinated integration of technical monitoring, contextual reasoning, policy awareness, and response governance. Research on automated cloud incident management supports this position, showing that cloud incidents must be handled both rapidly and in a structured manner [3,4]. Table 1 summarizes the 23 legacy studies, while Table 2 reports the 10 additional studies included from the Scopus update.

Table 1. Summary of the reviewed studies.

Ref.	Year	Type	Main Focus	Principal Contribution
[5]	2025	Survey	AI-augmented SOC, LLMs, agents	Reviews the use of LLMs and agent-based approaches for security automation in SOC environments.
[1]	2025	Conference paper	Cloud security, data center security	Discusses cloud data-center security challenges and mitigation strategies with emphasis on governance and standards.
[13]	2025	Preprint	Agentic AI in cybersecurity	Explains the evolution of Agentic AI from single-LLM reasoning to multi-agent and autonomous pipelines.
[3]	2024	Preprint	Cloud incident detection and response	Proposes an AI-enabled system for cyber-incident detection and response in cloud environments.
[6]	2025	Preprint	Human–AI collaboration, trusted autonomy	Presents a framework for trusted human–AI collaboration in SOC operations.
[29]	2025	Preprint	Few-shot cyber incident detection	Explores few-shot incident detection with augmented contextual intelligence.
[26]	2025	Journal article	NSOC troubleshooting, expert-aware support	Introduces an expert-aware Markovian system for proactive troubleshooting in security operations.
[14]	2025	Journal article	AI opportunities and risks in cyber defense	Discusses the broader promise and risks of AI in cyber defense.
[7]	2023	Journal article	AI-assisted SIEM, alert fatigue	Proposes an AI-assisted SIEM framework for reducing alert fatigue and improving response.
[16]	2026	Journal article	Agentic RAG for cyber reporting	Introduces CyberRAG for attack classification and report generation using agentic retrieval-augmented generation.
[11]	2025	Journal article	Hyper-automation, agentic SOAR	Examines robust SOAR through hyper-automation and Agentic AI.
[19]	2025	Preprint	Trust in AI-based incident response	Empirically studies automation readiness and trust in AI-supported cyber incident response.
[2]	2025	Preprint	Cloud security and NIST standards	Analyzes cloud security significance, providers, and standards alignment.
[27]	2022	Journal article	Network slicing security assurance	Examines security controls and assurance mechanisms in distributed network slicing contexts.
[8]	2022	Systematic review	SOC framework literature	Reviews the state of the art in SOC frameworks and related operational models.
[17]	2025	Journal article	AI-based automated response system	Presents computational modeling of an AI-based automated cybersecurity incident response system.
[12]	2025	Journal article	Wazuh, RAG, SOC copilot	Proposes a RAG-driven Wazuh copilot for SOC event response.
[18]	2025	Journal article	Wazuh with machine learning	Improves Wazuh threat detection through machine-learning techniques.
[28]	2023	Conference paper	SOCaaS for IoT using open-source SIEM	Presents a SOCaaS approach for IoT using open-source SIEM infrastructure.
[9]	2025	Journal article	Governance tensions in SOCs	Analyzes paradoxes and organizational tensions in security operations centers.
[15]	2025	Journal article	Agentic AI for cybersecurity transformation	Discusses how Agentic AI may transform cybersecurity practice against emerging threats.
[10]	2025	Journal article	Autonomous SOC, AI agents	Examines AI agents for threat triage, response, and orchestration in autonomous SOC models.
[4]	2024	Conference paper	Automated cloud incident management	Studies automated management of security incidents in public cloud environments.

Table 2. Additional studies included through the Scopus update.

Ref.	Year	Evidence Role	Contribution to the Synthesis
[30]	2026	Cloud RAG and threat modeling	Maps AWS CloudTrail evidence to MITRE ATT&CK using retrieval-augmented analysis.
[31]	2026	SOC alert triage	Compares LLM and classical baselines for alert classification and prioritization, showing weaker reliability for severity prioritization.
[32]	2026	SOC-focused survey	Synthesizes LLM uses across detection, analysis, and response phases of SOC work.
[33]	2025	Multitenant SOCaaS	Describes an open cloud service architecture with tenant isolation, telemetry processing, and machine-learning elements.
[20]	2025	Prompt-injection defense	Provides a formal and empirical defense against indirect prompt injection in AI agents.
[21]	2025	Agent red teaming	Automates black-box red teaming for indirect prompt injection against LLM agents.
[22]	2026	Multi-agent prompt injection	Demonstrates propagation of malicious instructions between interacting LLM agents.
[23]	2024	Agent-security benchmark	Supplies a dynamic environment for evaluating prompt-injection attacks and defenses.
[24]	2025	Agent-security benchmark	Formalizes attack and defense evaluation across LLM-based agents.
[25]	2025	Adaptive indirect injection	Shows that adaptive attacks can bypass multiple indirect-prompt-injection defenses.

4.3. SOC Modernization and the Operational Burden on Analysts

A significant finding is that contemporary SOC operations remain constrained by alert fatigue, high false-positive rates, analyst overload, staff shortages, fragmented tooling, and slow incident handling [5–10]. These problems become more severe in infrastructures that generate large event volumes and change rapidly [3,4,11,12].

Research on SOC modernization indicates that traditional rule-based and analyst-driven processes are no longer adequate for contemporary defensive requirements [5,7–10]. AI-supported SIEM solutions, hyper-automation strategies, and Wazuh-based extensions are therefore proposed as mechanisms for improving triage, prioritization, enrichment, and response coordination [7,11,12,18]. However, the review also indicates that modernization has been uneven. Some studies improve isolated SOC functions such as alert reduction or detection accuracy [7,18], whereas others propose more substantial changes to orchestration and semi-autonomous operation. The literature therefore addresses not only component-level improvement but also workflow transformation, although the maturity of this development varies considerably across studies.

4.4. AI Approaches Identified in the Reviewed Studies

The reviewed literature shows a progressive shift from traditional AI security approaches toward more adaptive and agentic models. Earlier and narrower approaches rely on machine-learning and deep-learning techniques for threat detection, signal analysis, and classification [14,18,29]. These studies show that AI can improve detection quality and reduce analyst workload, particularly in settings with high operational density. These approaches are useful for addressing practical SOC problems, but they typically operate at only one point in the incident-response process.

A complementary research stream applies LLMs to cybersecurity tasks [5,10–13,15,16]. These systems go beyond classification: they interpret events, generate reports, enrich incidents, support playbook execution, and perform multistep reasoning. AI therefore

functions not only as a detector but as a workflow component that supports triage, coordination, and incident-response decisions.

Comparison across these technologies clarifies their respective trade-offs. Machine-learning systems are narrower in scope but operationally predictable, whereas LLM-based and agentic systems are more flexible and more context-aware while raising stronger concerns about trust, hallucination, explainability, and control. The review therefore suggests that the most promising direction is not the general adoption of AI but the controlled introduction of specific AI functions into structured security workflows.

4.5. Emergence of Agentic and Semi-Autonomous Security Operations

One of the most significant outcomes of the review is the growing role of Agentic AI in the cybersecurity literature. Several recent studies extend beyond conventional automation and describe agentic systems as capable of using tools, performing multistep reasoning, decomposing tasks, retrieving contextual information, and orchestrating actions. These studies present Agentic AI as a potential response to the growing complexity of cloud security operations, particularly where incident response requires rapid access to multiple sources of telemetry, policy, and threat context.

However, the maturity of Agentic AI in security applications remains limited. Most papers are conceptual, survey-based, or framework-based and have not been tested in operational deployments [5,6,10,13–15]. In most cases, very little evidence is provided about how these approaches perform at scale or in real-world settings, even when sophisticated models of orchestration or agent-based cyber-defense pipelines are proposed. This does not diminish their conceptual importance, but it does show that the architectural vision has developed faster than the empirical validation.

A related observation is that the literature favors semi-autonomous operation over full autonomy. Human–AI collaboration, bounded autonomy, and orchestrated accountability are recurring themes [6,9,19]. Even in the agentic literature, AI contributions are described as supportive, controlled, or constrained rather than unrestricted. This is particularly important in cloud settings where operational decision-making can affect business continuity, compliance, and sensitive access control.

4.6. Role of RAG, Wazuh, and Open-Source Operational Ecosystems

The comparative review also identifies operational ecosystems built on open-source tooling and retrieval support. Studies using Wazuh indicate that reproducible SOC capabilities can be developed without exclusive reliance on costly proprietary platforms [12,18,28]. These studies support the use of open-source SIEM components for cloud security and show how machine learning or RAG can extend their capabilities.

RAG-oriented work addresses one of the main weaknesses of applying general-purpose LLMs to cybersecurity, namely the absence of operational context. By connecting security reasoning to playbooks, threat frameworks, prior case knowledge, and operational documentation, retrieval-based systems improve contextual accuracy and deliver operationally relevant recommendations. RAG therefore serves as an effective intermediary between strict rule-based reasoning and more open agentic reasoning.

These studies also share a common limitation. Open-source and RAG-enhanced implementations tend to prioritize functional improvements such as enrichment, reporting, and threat classification, while addressing governance, accountability, and authorization in less detail. They therefore make valuable practical contributions without fully addressing the broader requirements of cloud-scale security orchestration.

4.7. Prompt Injection and Adversarial Agent Risks

The transition from analytical assistance to tool-using agents changes the SOC threat model. Cloud telemetry is untrusted by definition because an attacker may influence log messages, resource names, API parameters, tickets, email content, or threat-intelligence artifacts. If these data are placed directly into an agent context, malicious text may be interpreted as an instruction rather than as evidence. The resulting direct or indirect prompt injection can alter prioritization, suppress alerts, redirect retrieval, disclose contextual information, or induce an unauthorized tool request. AgentDojo and Agent Security Bench formalize this exposure, while MELON, AgentVigil, Prompt Infection, and adaptive-attack evaluations show both the value and limitations of current defenses [20–25]. These concerns become more consequential when an agent is connected to cloud control-plane or SOAR tools.

Retrieval introduces a closely related risk. A corrupted playbook, historical case, or external intelligence record can poison the evidence supplied to the reasoning layer, and tool use amplifies the consequences because an incorrect recommendation may become an operational action. Adversarial studies show that grounding alone does not guarantee instruction integrity [20,21,23–25], although cloud-based RAG can support evidence mapping and contextual analysis [30]. These findings motivate four architectural requirements: separating instructions from data, retrieving from controlled sources in a provenance-aware manner, restricting tool access, and applying authorization outside the language model.

4.8. Governance, Explainability, and Forensic Preparedness

A central insight from the literature is that trust and governance are not afterthoughts but necessary components of intelligent security operations. Studies of human–AI collaboration, organizational tensions in SOCs, and trust in AI-generated responses consistently report that SOC personnel value automation for reducing manual workload and improving efficiency, while also recognizing that automated responses require human supervision to prevent consequential errors [6,9,19]. This concern is especially pronounced in cloud environments, where automated actions such as disabling an account, isolating a workload, or changing a configuration can have substantial technical and organizational effects [1,2,4].

The literature also devotes uneven attention to explainability and forensic preparedness. Some studies emphasize transparency, bounded autonomy, and human approval [6,9], whereas others emphasize functional capability without addressing post-decision accountability [10,12,16,17]. The review indicates that the principal gap in the field is not a shortage of intelligent techniques but the limited integration of those techniques with auditable workflows, policy constraints, and investigable evidence trails.

This observation is directly relevant to this paper, as it supports the position that future Agentic AI-based SOCaaS designs must provide governance guardrails as well as orchestration capability. The literature accepts intelligent response assistance, but only where auditability, traceability, and human authority are preserved in high-stakes settings.

4.9. Comparative Interpretation of Maturity Across the Literature

Read comparatively, the reviewed studies fall into three broad levels of maturity. The first level comprises research that enhances isolated detection or triage capabilities, including AI-assisted SIEM filtering, few-shot incident detection, and machine-learning improvements to Wazuh [7,18,29]. These studies are practically useful and often easier to evaluate, but operationally limited. The three general levels of maturity determined in the studies reviewed are summarized in Figure 3.

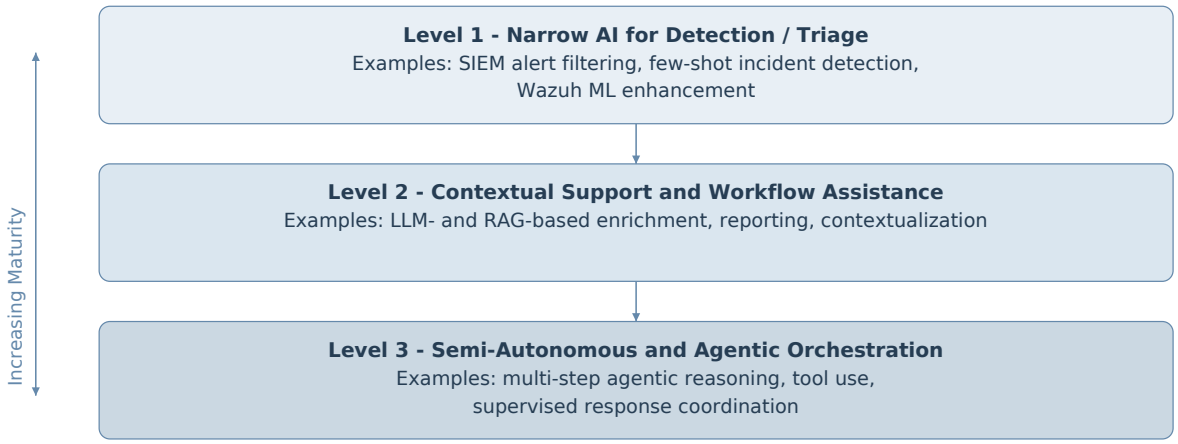


Figure 3. Comparative interpretation of maturity across the reviewed literature. The field progresses from narrow AI support toward contextual workflow assistance and, finally, toward semi-autonomous and agentic orchestration models. The studies represented at each level are: Level 1 [7,18,29]; Level 2 [5,12,16]; and Level 3 [6,10,11,13,15,17].

The second level comprises studies that extend AI to contextual support, reporting, enrichment, and workflow assistance, particularly LLM- and RAG-based systems [5,12,16]. These approaches offer richer decision support and align more closely with current SOC practice, but they do not provide controlled end-to-end action orchestration.

The third level comprises work that conceptualizes or models semi-autonomous and agentic security processes [6,10,11,13,15,17]. These papers are the most ambitious, because they address the entire action chain from detection to coordinated response. They are also the least mature in validation terms, as most are conceptual or framework-based and have not been validated to a level that would support live-cloud implementation.

This comparison suggests that cloud security operations are likely to converge on a synthesis of all three levels: narrow AI for specific tasks, retrieval-assisted intelligence for contextualization, and agentic coordination for workflow organization. The literature does not identify a single replacement technology but points toward an integrated operational architecture in which different forms of AI serve different roles under explicit governance constraints.

4.10. Summary of Comparative Findings

Overall, the review indicates convergence on several significant findings. First, cloud security requires faster, more adaptive, and more context-aware operational models than conventional analyst-driven methods. Second, existing SOC environments are sufficiently strained to justify greater automation and AI-supported assistance. Third, AI in cybersecurity is shifting away from the limited support of detection to LLM-based reasoning, contextualization through retrieval, and agentic orchestration. Fourth, this transformation is limited by unaddressed issues with regard to trust, governance, explainability, and validation. Fifth, semi-autonomous SOC futures are indicated in a number of studies, but there is still little empirical evidence, particularly in real-world cloud incident-response environments.

The following stage of the paper is directly motivated by these findings: a critical discussion of the key trade-offs and conceptual framework integrating intelligent orchestration and policy-aware control with human oversight and auditable cloud incident response. Table 3 compares the main categories of intelligent security approaches identified in the review, together with their typical strengths and limitations.

Table 3. Comparative classification of intelligent security approaches identified in the review.

Category	Representative Studies	Typical Strengths	Typical Limitations
Narrow AI for detection and triage	[7,18,29]	Improves signal filtering, classification accuracy, alert prioritization, and operational efficiency in bounded tasks.	Often limited to one stage of the SOC pipeline; usually weak in contextual reasoning, governance integration, and end-to-end response support.
LLM-assisted contextual support	[5,12,16]	Enhances explanation, reporting, enrichment, contextualization, and analyst assistance in day-to-day workflows.	May suffer from hallucination, inconsistency, or insufficient grounding if retrieval and policy constraints are weak.
RAG-grounded reasoning and assistance	[12,16]	Improves contextual grounding by linking outputs to playbooks, prior cases, policies, and threat frameworks.	Still often focused on support functions rather than governed action execution; depends on quality of retrieved knowledge sources.
Agentic and semi-autonomous orchestration	[10,11,13,15,17]	Supports multistep reasoning, task decomposition, tool coordination, and broader workflow orchestration.	Validation remains limited; raises stronger concerns around trust, bounded autonomy, explainability, and action governance.
Open-source operational ecosystems	[12,18,28]	Offer practical, extensible, and comparatively accessible implementation pathways for SOC improvement.	May emphasize functionality over governance, accountability, and enterprise-scale policy integration.
Governance and human–AI collaboration models	[6,9,19]	Highlight transparency, trust calibration, approval boundaries, and organizational control in intelligent operations.	Often conceptual or evaluative rather than deeply integrated with full operational cloud-response architectures.

4.11. Integrated Discussion

This review reveals that the security of cloud computing can no longer be successfully managed through fixed controls, isolated detectors, and incident-management processes guided only by human analysts. The literature indicates that the scale, dynamism, API dependency, distributed control planes, and governance complexity of cloud environments place excessive strain on existing security-operations models [1–4]. At the same time, traditional SOC workflows continue to face alert fatigue, false positives, tool fragmentation, staffing pressure, and slow response times [5,7–10]. Together, these pressures contribute to growing interest in AI-enhanced and agentic solutions for quicker, more context-sensitive, and more coordinated security operations.

One of the most striking conclusions of the works reviewed is that modernization of security operations is not simply a matter of increasing automation. Instead, the literature suggests that the deeper issue lies in incorporating intelligent automation into operationally realistic, policy-conscious, and trustworthy working processes. This is especially important in cloud environments, where security actions such as credential removal, workload isolation, or configuration changes can affect availability, compliance, customer trust, and business continuity [1,2,4]. For that reason, intelligent security operations are treated in the literature as a design problem that must be directed and constrained by organizations as much as it is enabled technically.

Among the clearest findings of the review is the difference between functional improvement and operational transformation. Some studies enhance particular tasks, such as alert prioritization, threat detection, context-enhanced classification, or open-source SIEM operation [7,18,29]. Such contributions focus on actual SOC pain points and may be easier to assess than larger architectural projects, but they are typically limited to one part of the incident-response pipeline. In comparison, papers that emphasize orchestration, hyper-automation, agentic reasoning, or human–AI collaboration strive to place se-

curity operations in a system-wide perspective [6,10,11,13,15,17]. They are more suitable for cloud-operational needs, but they are also earlier on the validation path, which indicates that the literature has advanced conceptually faster than operationally.

A second important theme is the shift from narrow AI support toward broader and more general forms of assistance. Machine learning contributes classification, filtering, and signal enhancement, while more recent work on RAG, LLMs, and agentic systems extends AI to contextual retrieval, explanation, reporting, enrichment, and multistep reasoning. This shift is significant because it brings AI closer to actual analyst practice: analysts spend less time detecting anomalies than contextualizing situations, consulting playbooks, interpreting cloud policy, and deciding on response actions. The literature therefore suggests that AI will contribute to security operations less through automation than through contextual orchestration.

The same literature shows that greater flexibility also increases risk. The more extensively an AI system reasons, the greater the need for explainability and for explicit limits on its responsibility and authority. This produces a central tension in the field: the properties that make Agentic AI attractive for cloud incident response (speed, flexibility, tool use, and decision support) are also the properties that make it hazardous unless constrained by governance safeguards. The review therefore supports a qualified conception of autonomy, in which semi-autonomous models bounded by policy are more convincing than unrestricted autonomous response.

The reviewed studies provide a clear rationale for this conclusion. Reliable autonomy in SOCs depends on human–machine cooperation that is explainable, manageable, and integrated with existing workflows, which in turn increases the likelihood that analysts will trust the system [6,9,19]. Trust is not only a psychological matter but also an organizational and action-governance matter. In practice, cloud security operations cannot be built around vague recommendations or opaque automated actions, particularity when incidents involve privileged access, regulated resources, or business-critical services. Intelligent systems are instead expected to support reasoning, record decision history, and respect authority and escalation boundaries. These are among the most important governance and forensic-preparedness requirements for an Agentic AI-based SOCaaS.

Open-source and retrieval-supported ecosystems also contribute substantially to this transition. Wazuh-based studies show that operational platforms can provide practical, extensible, and comparatively accessible means of improving SOC capability [12,18,28]. Likewise, RAG-based studies show that contextual relevance can be improved by grounding model behavior in retrieved operational knowledge. The significance of these developments is that they offer realistic implementation directions rather than purely abstract visions. However, they do not always address governance comprehensively, and the literature still provides limited evidence that such tool-coupled systems are consistently paired with strong policy checks, approval limits, and audit mechanisms.

A review of the methodology across the corpus reveals that the field is still immature. The papers consist mostly of systematic reviews, conceptual frameworks, preprints, architectural propositions, or preliminary implementation studies [5,6,8–11,13–15]. This is understandable in a rapidly evolving domain shaped by LLMs, RAG, and agentic systems, but it also weakens the empirical inferences that can be made at present. No reviewed studies provide strong real-world evidence about the performance of intelligent or agentic security systems under realistic cloud incidents, analyst interaction, and governance or compliance constraints. Building more intelligent systems is therefore not only a future research agenda but a task that requires considerable care if it is to be viable in real cloud security operations.

As a principle, the literature under consideration does not expect the future of cloud security operations to be either fully manual or fully autonomous. In high-stakes, dynamic, and controlled cloud environments, a fully independent model is difficult to sustain, and a fully analyst-driven model becomes increasingly difficult as telemetry volume and response demands grow. A hybrid solution, in which AI and agentic systems are used to triage, contextualize, aid decision-making, and coordinate low-risk or predetermined actions while high-impact or policy-specific decisions remain with human analysts, appears most plausible. Most studies align with this view of bounded autonomy, semi-autonomous orchestration, and the need to balance speed with control in security operations [6,9,11,15].

This position motivates the contribution of this paper. The literature establishes that cloud security operations must become both more intelligent and more controllable, but it addresses these two requirements in largely separate research streams. The following section therefore presents an architectural model that unifies them within a single operational pipeline comprising cloud telemetry ingestion, automated triage, retrieval-supported context, agentic reasoning, deterministic policy enforcement, human oversight, and auditable response execution. This integration is what the proposed Agentic AI-driven SOCaaS framework is intended to provide.

5. Proposed Agentic AI-Driven SOC-as-a-Service Framework

5.1. Threat Model and Trust Boundaries

The framework assumes that telemetry, analyst-provided text, external threat intelligence, retrieved documents, and tool responses may contain attacker-controlled content. Protected assets include cloud credentials, tenant data, incident evidence, system instructions, response playbooks, tool permissions, approval decisions, and audit records. Relevant adversaries include external attackers able to influence telemetry, malicious insiders, compromised tenants, and compromised knowledge or tool integrations. These assumptions extend the governance and trusted-autonomy concerns identified in the reviewed literature [6,9–11,14,15,19] to the specific context of tool-using SOC agents.

Four trust boundaries govern information flow. First, an evidence boundary separates untrusted telemetry from trusted instructions and preserves source provenance. Second, a knowledge boundary restricts retrieval to authorized, versioned, and attributable sources. Third, a decision boundary treats model output as a recommendation rather than an authorization. Fourth, an execution boundary independently validates the proposed tool, parameters, tenant, policy, and approval before any action is performed. High-impact actions cannot be authorized by the agent itself. This separation is consistent with the literature's preference for bounded autonomy and human authority over consequential decisions [6,9,11,19].

5.2. Framework Rationale

As the comparison and discussion show, cloud security operations are moving toward greater automation, contextual reasoning, and orchestration across detection, triage, investigation, and response. At the same time, unresolved problems of governance, explainability, bounded autonomy, and forensic preparedness constrain this shift, reinforced by legal and regulatory requirements, information-management obligations, and information-security standards.

The framework does not assume that Agentic AI will replace human analysts or make unconstrained decisions. Instead, it positions Agentic AI as a controlled orchestration layer within a cloud-based SOC-as-a-Service model. The agentic layer supports multi-step reasoning, tool coordination, contextual retrieval, and decision support, while deter-

ministic governance rules and human supervision constrain high-impact actions. The reviewed evidence therefore supports bounded, semi-autonomous operation rather than unrestricted automation.

The fragmentation of the current research landscape further motivates the framework. Existing research tends to treat cloud governance, SOC automation, AI, RAG, and agentic orchestration as distinct but interconnected topics. The proposed model integrates these strands into a single coherent architecture for cloud incident response. It therefore serves both as a conceptual synthesis of the reviewed literature and as a design reference for the future development and evaluation of prototypes.

5.3. Design Principles of the Framework

The proposed framework is guided by nine design principles derived from the literature. The first six address operational scope, decision support, orchestration, oversight, auditability, and modularity; the remaining three address the adversarial and multitenant requirements identified in Section 5.1 and in the agent-security literature.

1. **Cloud-centered operational awareness.** The framework assumes that cloud systems generate distributed, high-volume, and dynamic telemetry. Incident-response support must therefore operate across cloud audit logs, IAM activity, API traces, SIEM signals, endpoint events, and infrastructure metadata rather than a single event source [1–4].
2. **Context-rich decision support.** Retrieval-supported reasoning is included because cloud incidents are frequently ambiguous and require context about assets, policies, and identities. This enables the system to consult playbooks, threat-intelligence mappings, historical incidents, and governance documentation before proposing response actions [12,16].
3. **Bounded agentic orchestration.** The framework allows the agentic layer to coordinate tools, decompose tasks, and support multistep incident workflows. However, this orchestration is bounded by organizational policies, escalation rules, and risk thresholds so that autonomy remains controlled and explainable [6,9,11].
4. **Human-centered oversight.** The framework presumes that human analysts are still indispensable, especially in cases of ambiguous, high-risk, or business-sensitive incidents. Analysts are assisted by AI with triage, contextualization, prioritization, and response recommendations instead of being displaced [5,6,9,19].
5. **Auditable and forensically useful execution.** Any high-level reasoning processes, retrieval operations, recommendations, approval decisions, and performed responses should be documented in a way that enables post-incident investigation, compliance checking, and evidence preservation [6,9].
6. **Modular integration with SOCaaS operations.** The framework is designed to accommodate SOC-as-a-Service environments where security services can be shared among different clients, settings, and cloud services. This demands modularity, service-oriented integration, and policy-sensitive customization rather than a single operational pipeline [5,10,28].
7. **Adversarially robust context handling.** Telemetry and retrieved text are treated as untrusted evidence rather than instructions. Provenance, schema validation, canonicalization, content labeling, and prompt-injection screening are applied before information reaches the reasoning layer. This principle operationalizes the broader requirements for adversarial robustness and trustworthy autonomy identified in AI-enabled cyber defense [6,11,14,15].
8. **Least-privilege and policy-mediated execution.** The agent may formulate an action proposal but cannot grant itself authority or directly relax an organizational policy.

Tools are exposed through allowlisted operations with constrained parameters and tenant-specific credentials. A deterministic policy mechanism outside the generative model decides whether an action is denied, automatically permitted, or submitted for human approval [6,9,11,19].

9. **Tenant and context isolation.** Because SOCaaS may serve multiple organizations, prompts, working memory, retrieved documents, credentials, and audit records must remain tenant scoped. Cross-tenant retrieval and tool execution are denied by default. This extends the modular SOCaaS model described in the literature [10,28] with an explicit confidentiality boundary required for shared cloud operations.

5.4. Core Layers of the Proposed Framework

The proposed Agentic AI-driven SOCaaS framework consists of six core layers that work together to support cloud incident response. The overall structure of the proposed framework is illustrated in Figure 4.

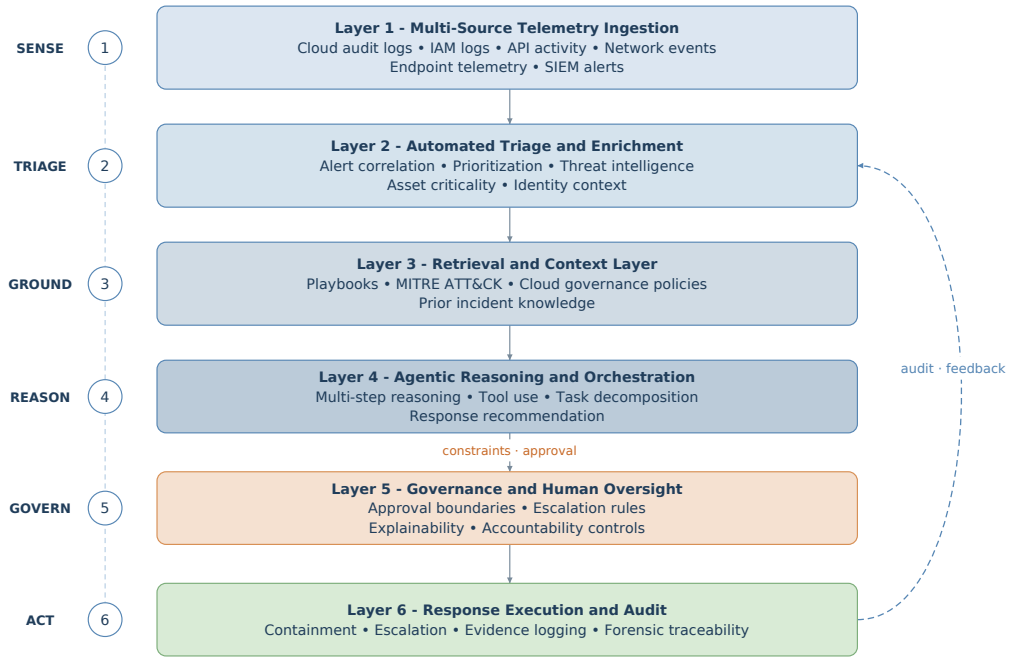


Figure 4. Proposed Agentic AI-driven SOCaaS framework for cloud incident response. The architecture integrates telemetry ingestion, automated triage, retrieval-supported reasoning, bounded agentic orchestration, governance-aware human oversight, and auditable response execution.

5.4.1. Cross-Cutting Agent Security and Trust-Enforcement Plane

The six operational layers are governed by a cross-cutting security plane rather than protected by a single final-stage filter. At ingestion, it verifies source and tenant identity, validates schemas, canonicalizes fields, preserves raw evidence, and labels telemetry as untrusted. At retrieval, it enforces source allowlists, access control, document versioning, and provenance recording. At reasoning, it separates system policy from evidence, restricts memory and iteration, and requires structured action proposals. At governance and execution, it applies deterministic policy checks, least-privilege credentials, tool and parameter allowlists, human approval, rate limits, rollback controls, and tamper-evident audit records. These controls translate trusted-autonomy and governance requirements from the reviewed literature into explicit architectural responsibilities [6,9–11,14,15,19]. Table 4 maps the principal adversarial threats to the corresponding architectural controls.

Table 4. Principal adversarial threats and corresponding architectural controls.

Threat	Attack Channel	Potential Consequence	Primary Controls
Direct prompt injection	Analyst or operator input	Instruction override or disclosure	Instruction–data separation, input labeling, and policy enforcement
Indirect prompt injection	Logs, alerts, tickets, or resource metadata	Distorted reasoning or unauthorized tool proposal	Canonicalization, structured parsing, provenance, and injection screening
Retrieval poisoning	Playbooks, historical cases, or intelligence sources	Unsupported or malicious recommendation	Trusted-source allowlists, access control, signing, and versioning
Tool misuse	Agent-generated action request	Service disruption or privilege abuse	Least privilege, tool and parameter allowlists, and external authorization
Cross-tenant leakage	Shared context, memory, or retrieval	Confidentiality breach	Tenant-scoped context, credentials, retrieval, and audit storage
Audit manipulation	Evidence or decision records	Loss of accountability and forensic value	Append-only, tamper-evident records with timestamps and actor identities

5.4.2. Multi-Source Telemetry Ingestion Layer

The first layer standardizes and normalizes telemetry from a variety of operational sources, including cloud audits, IAM logs, API activity, workload telemetry, network events, endpoint agents, SIEM alerts, and other suitable contextual metadata. This layer provides the common operational picture required for credible incident detection and interpretation. Cloud environments require normalization and correlation, as assets may be short lived and event volume is high, to transform raw signals into incident context that can be acted on in practice [1–4].

5.4.3. Automated Triage and Enrichment Layer

The second layer performs alert correlation, prioritization, and enrichment. It combines raw security indicators with threat-intelligence references, asset significance, identity information, past case history, vulnerability context, and environmental metadata. This reduces analyst burden and improves the quality of incident candidates before more detailed reasoning takes place. The literature on AI-assisted SIEM and Wazuh optimization strongly indicates that this layer can effectively reduce alert fatigue and improve signal relevance [7,12,18].

5.4.4. Retrieval and Context Layer

The third layer provides contextual grounding through retrieval-augmented processes. It enables the framework to consult security playbooks, cloud governance policies, MITRE ATT&CK mappings, incident-response procedures, and historical knowledge relevant to the current sequence of events. This layer is particularly important because ungrounded language-model reasoning can be incomplete or inaccurate, whereas retrieval-supported reasoning improves the situational relevance and usefulness of recommendations [12,16].

5.4.5. Agentic Reasoning and Orchestration Layer

The fourth layer provides the central reasoning capability. The agentic system interprets the incident, decomposes the problem into subtasks, identifies relevant tools or information sources, conducts a multistep analysis, and generates response recommendations. Depending on organizational policy and maturity level, the agent may also execute low-risk actions such as opening an incident case, escalating an alert, proposing containment measures, generating an investigation summary, or forwarding evidence to the relevant analyst [10,11,13,17].

The layer is agentic in that it supports goal-directed reasoning and tool coordination rather than single-step classification. Its behavior is nevertheless bounded by the governance layer, and it does not act as an independent controller.

5.4.6. Governance and Human Oversight Layer

The fifth layer ensures that system behavior is consistent with policy, authority boundaries, risk tolerance, and accountability provisions. Before any response action is executed, the framework checks the proposed action against the applicable policy rules. Low-risk actions may be pre-approved for automatic execution, whereas high-risk operations, such as disabling privileged identities, isolating production workloads, or modifying critical cloud configurations, require review by a human analyst [6,9,19].

This layer also supports explainability: every proposed action must be accompanied by its rationale, its supporting evidence, and the sources consulted. The framework thereby enables meaningful human supervision rather than nominal authorization.

5.4.7. Response Execution and Audit Layer

The sixth layer takes approved measures and records the incident-management process step by step. Example measures include case creation, alert escalation, evidence packaging, credential revocation, temporary containment, notification, or coordination of downstream SOAR activity. Every step taken must be documented, along with referenced data sources, approvals, and timing information. This strengthens forensic preparedness and management accountability, which are recurring concerns in the literature [6,9].

5.5. Illustrative Incident-Response Workflow

To demonstrate how the framework functions in practice, consider a cloud incident involving suspicious privilege escalation and anomalous API activity in a multi-cloud environment. In this scenario, a cloud platform generates a sequence of events showing unusual identity behavior, repeated token activity, access to sensitive storage resources, and abnormal control-plane operations. Figure 5 illustrates the operational flow of the proposed framework in a cloud privilege-escalation scenario.

First, the telemetry ingestion layer collects the relevant cloud audit events, IAM logs, SIEM alerts, and workload context. Second, the triage layer correlates these events and enriches them with asset criticality, identity history, prior incidents, and threat signals. Third, the retrieval layer consults organizational response playbooks, cloud-access policies, and threat-framework mappings to contextualize the activity and determine whether it matches a known attack pattern such as credential abuse, privilege escalation, or lateral movement.

The agentic reasoning layer then combines this information and generates a ranked set of response options with associated confidence scores. These may include opening an investigation case, escalating to a senior analyst, temporarily blocking the suspicious credentials, or recommending isolation of a cloud workload. The governance layer verifies that the selected option remains within the automation limits defined by policy before any action proceeds. Documentation, enrichment, and low-risk escalation may be executed automatically, whereas high-impact actions, particularly those affecting privileged access or production resources, are routed to a human operator for approval.

Once approval is granted, the response execution layer performs the approved action and records all relevant decisions, evidence, retrieval steps, and approvals in an auditable log. This produces a closed traceability loop that supports investigation, compliance review, and post-incident learning. The workflow therefore balances speed against control and couples automated coordination with bounded authority.

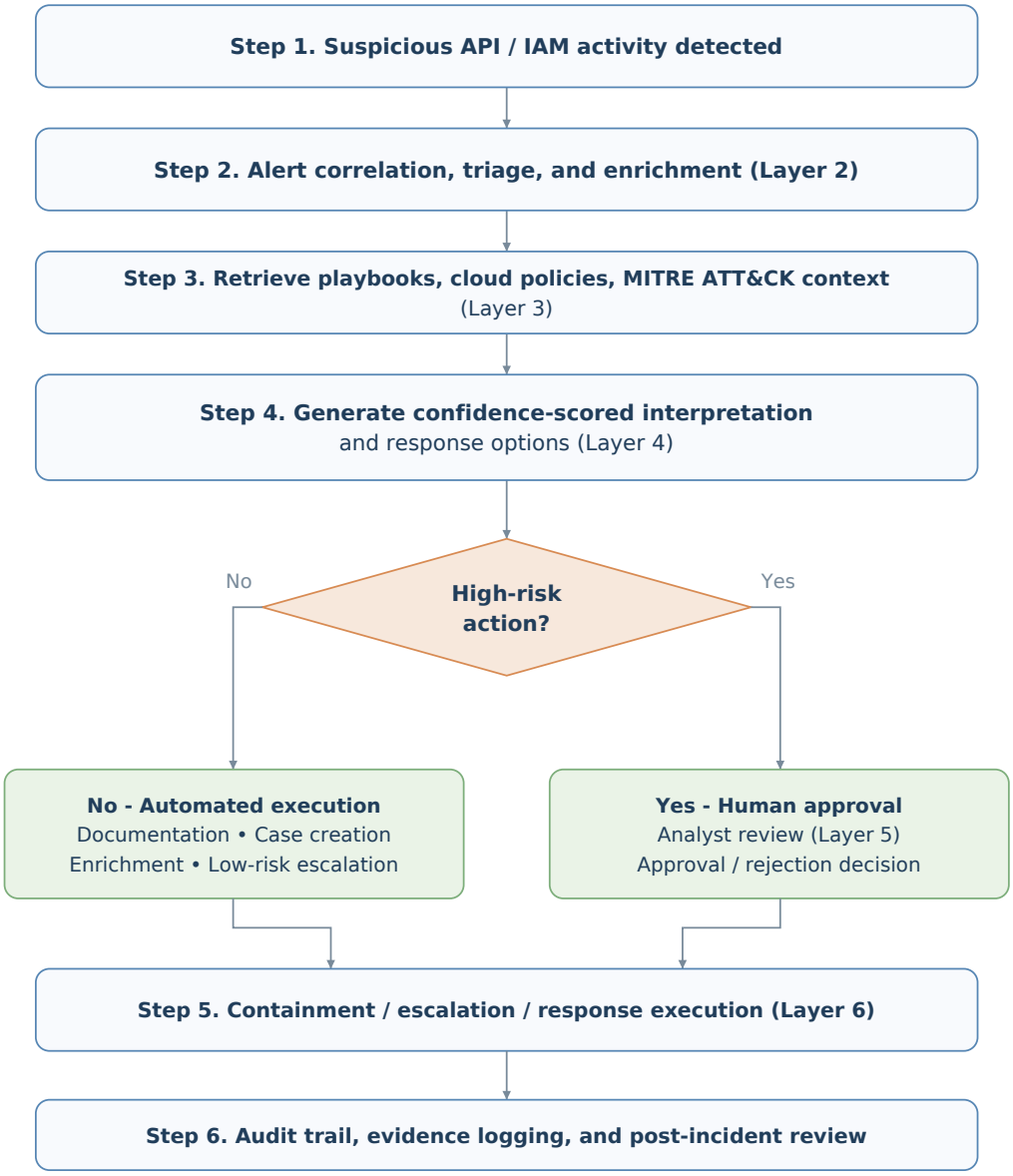


Figure 5. Illustrative workflow of Agentic AI-supported response to a cloud incident involving privilege escalation or anomalous API activity. Low-risk actions may be executed automatically, whereas high-impact action require human approval under governance constraints.

5.6. Relationship to Existing Literature

The framework is integrative of many strands of the literature studied. Its telemetry and cloud context are based on cloud security and cloud incident-response research [1–4]. Its triage, enrichment, and operational support functions align with research on AI-assisted modernization of SOC and SIEM workflows [5,7,12,18]. Its contextual grounding and retrieval features are anchored in RAG-oriented security studies [12,16]. Its orchestration reasoning draws on agentic and hyper-automation work in cybersecurity [10,11,13,15,17]. Finally, its governance, authorization, and responsibility factors are mediated by literature on trusted autonomy, human–AI collaboration, and tensions in security operations organizations [6,9,19].

This constitutes one of the principal conceptual contributions of the paper. The framework treats AI capability, cloud context, and governance control not as separate concerns but as mutually reinforcing requirements for the development of trusted cloud SOCaaS.

5.7. Contribution and Intended Use of the Framework

The framework is evaluated through component-level simulation in Section 6, but it is not presented as a production implementation or a substitute for live-cloud and adversarial evaluation. Its primary contribution is conceptual and architectural: it describes how Agentic AI can support cloud-based SOCaaS while remaining bounded by external policy, human authority, tenant isolation, and auditable control.

The framework is intended to serve three functions. First, it provides a coherent synthesis of otherwise fragmented research areas. Second, it offers a reference point for developing and comparing future prototypes. Third, it helps specify what a policy-aware and trustworthy form of Agentic AI-driven cloud incident response should offer beyond automation and operational plausibility alone.

Overall, the framework reflects the view that the future of cloud security operations lies not in unrestricted autonomy but in the disciplined and coordinated application of agentic capabilities that augment human capacity without compromising accountability, auditability, or organizational authority.

6. Experimental Validation

This section presents a simulation-based component evaluation of the proposed Agentic AI-driven SOCaaS framework. The purpose is to examine internal consistency and selected operational behaviors under controlled assumptions, not to demonstrate production performance or adversarial robustness of a deployed LLM agent. The four experiments address automated triage and enrichment (Layer 2), lexical retrieval grounding (Layer 3), governance-gated orchestration (Layers 4 and 5), and closed-loop response execution with audit completeness (Layer 6). Experiment 1 evaluates a conventional machine-learning triage component rather than the generative reasoning layer. Experiment 2 uses TF–IDF as a transparent lexical retrieval baseline rather than as a state-of-the-art dense RAG implementation. Experiments 3 and 4 evaluate modeled queueing and record-completeness behavior; their parameters are scenario assumptions rather than production measurements. Accordingly, the results are interpreted as feasibility evidence conditional on the stated model.

6.1. Methodology, Simulation Environment, and Assumptions

The experiments were implemented in Python 3 using scikit-learn for machine-learning components, NumPy for stochastic modeling, and a custom discrete-event simulator for the orchestration experiments. All random processes use seed 42 to make repeated execution deterministic when the same implementation and environment are used. The complete simulation source and machine-readable outputs are openly released to permit independent reproduction (see the Data Availability Statement). Because no public dataset couples multi-source cloud telemetry with governance decisions and audit trails, we generate synthetic data whose statistical properties are calibrated to be deliberately imperfect: class-conditional feature distributions overlap, 3% of ground-truth labels are corrupted to emulate noisy SOC-derived labeling, incident descriptions contain distractor terms and cross-domain ambiguity, and evidence logging is subject to transient failure. This calibration is intentional; a validation exercise on cleanly separable data would overstate the capability of every layer. Our experimental design rests on the following numbered assumptions:

1. Telemetry events are drawn from five ground-truth classes: benign noise (70%), credential abuse (9%), lateral movement (8%), privilege escalation (7%), and data exfiltration (6%), reflecting the benign-dominated alert mixes reported in the alert-fatigue literature [5,7,8].

2. Each event is described by twelve features derived from the telemetry sources of Layer 1 (IAM activity, API traces, network flow, endpoint signals, and SIEM enrichment), such as failed-authentication ratio, privileged-role assumptions, east–west connection rate, and egress volume.
3. The SOC operates a single queue served by six analysts; incident inter-arrival times are exponential with a baseline rate of 12 incidents per hour, and analyst handling times are lognormal and depend on incident impact class.
4. Thirty percent of incidents require a high-impact response (e.g., disabling privileged identities or isolating production workloads); the agentic risk score correlates with, but does not perfectly predict, this ground truth.
5. The governance gate (Layer 5) auto-executes an action only when the risk score is below a configurable threshold; all other actions are escalated to a human analyst for approval, consistent with the bounded-autonomy position of the reviewed literature [6,9,19].
6. Evidence logging at each of the six framework layers is subject to a small per-step failure probability (0.4–1.0%) representing transient I/O errors and race conditions in distributed logging pipelines.

6.2. Experiment 1: Automated Triage and Enrichment (Layer 2)

In the first experiment, we model the automated triage and enrichment layer as a supervised classification problem. We generate 20,000 telemetry events under Assumptions 1 and 2 and train a Random Forest classifier (200 trees, maximum depth 14) on a 70% stratified training split, evaluating on the remaining 6000 events. Table 5 reports the per-class results, and Figure 6 shows the normalized confusion matrix and per-class F1-scores.

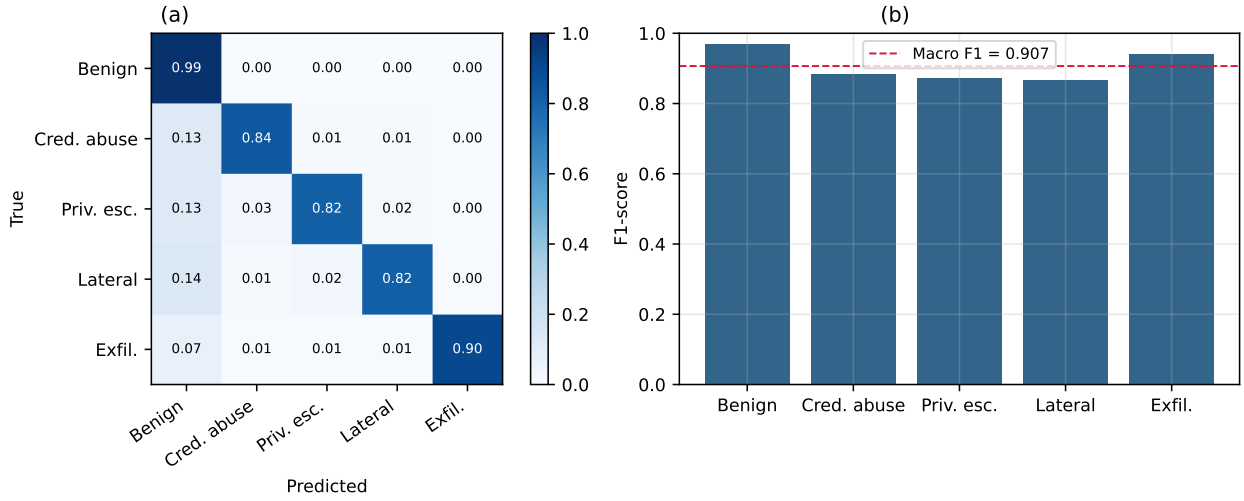


Figure 6. Triage and enrichment layer performance: (**a**) normalized confusion matrix; (**b**) per-class F1-scores against the macro-F1 reference line.

Walking through Table 5, the classifier attains a macro F1-score of 0.907 and an overall accuracy of 0.945. The benign class is recovered almost completely (recall 0.991), which is the property that matters most for alert-volume reduction. Recall on the four threat classes ranges from 0.816 (privilege escalation) to 0.904 (data exfiltration). This ordering is intuitive because data exfiltration is characterized by storage-read and egress volumes that are an order of magnitude above the benign baseline, whereas privilege escalation shares IAM-activity features with both credential abuse and benign administrative work, and is further degraded by the injected label noise.

Table 5. Per-class classification performance of the triage and enrichment layer (test set, $n = 6000$).

Class	Precision	Recall	F1-Score	Support
Benign/noise	0.946	0.991	0.968	4110
Credential abuse	0.930	0.844	0.885	565
Privilege escalation	0.935	0.816	0.872	441
Lateral movement	0.925	0.817	0.868	497
Data exfiltration	0.980	0.904	0.941	387
Macro average	0.943	0.875	0.907	6000
Weighted average	0.944	0.945	0.943	6000

Table 6 translates classification quality into the operational quantity the SOC literature cares about: how many alerts never reach an analyst. Under a plain argmax policy, 71.8% of the alert stream is suppressed, but 12.22% of true threats are suppressed with it. We therefore also evaluate a conservative gating policy in which an alert is suppressed only when the model assigns the benign class a posterior probability of at least 0.90. This reduces alert volume by 59.5% while cutting threat leakage to 4.81%. This result is important because it demonstrates, quantitatively, the central design position of the framework: the value of the triage layer is not raw accuracy but a tunable trade-off between analyst workload and risk tolerance, which is itself a governance parameter rather than a purely technical one.

Table 6. Operational suppression metrics of the triage layer under two escalation policies.

Metric	Argmax Policy	Conservative Gate ($p \geq 0.90$)
Alert volume reduction (not escalated)	71.8%	59.5%
Benign suppression rate	99.1%	84.7%
Threat leakage (threats suppressed as benign)	12.22%	4.81%

6.3. Experiment 2: Retrieval Grounding (Layer 3)

The second experiment quantifies the contribution of the retrieval and context layer. We construct a corpus of twelve response playbooks, each mapped to a MITRE ATT&CK technique, for example T1078 Valid Accounts, T1548 Abuse Elevation Control Mechanism, T1567 Exfiltration to Cloud Storage, and T1562 Impair Defenses, and sixty paraphrased incident descriptions (five per playbook) containing distractor terms; 20% of descriptions receive an additional cross-domain token to emulate the ambiguity of real incident narratives. We compare two configurations. In the grounded configuration, incident descriptions are matched against the full playbook corpus using TF–IDF vectorization (unigrams and bigrams, sublinear term-frequency scaling) with cosine similarity, representing Layer 3 retrieval. In the ungrounded configuration, the reasoning component has access only to playbook identifiers and titles, emulating a language-model prompt that lists available playbooks without a retrieval corpus. Table 7 and Figure 7 report the results.

Table 7. Playbook and ATT&CK mapping accuracy with and without retrieval grounding (60 queries, 12 playbooks).

Configuration	Top-1 Accuracy	Top-3 Accuracy
Ungrounded (titles only, no corpus)	0.317	0.583
Grounded retrieval (TF–IDF corpus)	0.850	0.933

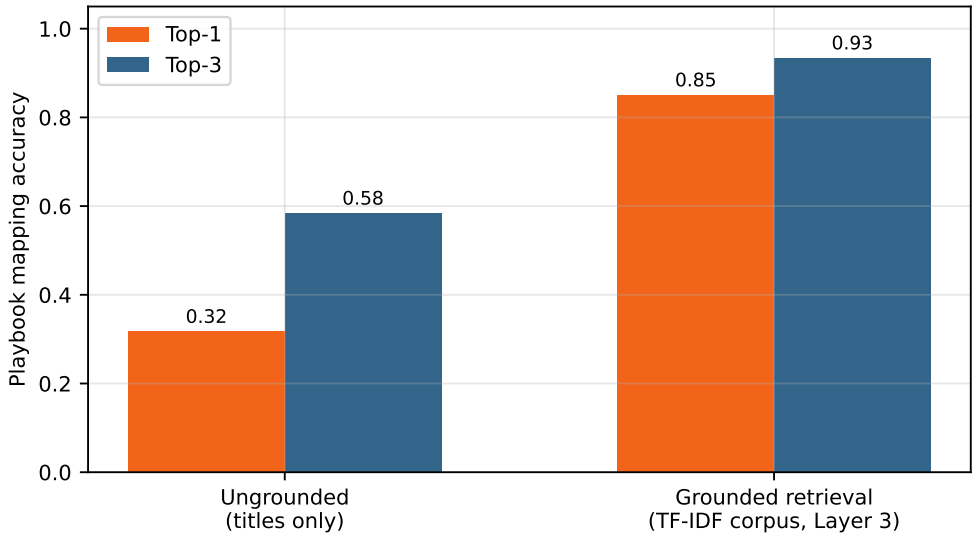


Figure 7. Retrieval grounding raises top-1 playbook mapping accuracy from 0.317 to 0.850 and top-3 accuracy from 0.583 to 0.933.

Grounding the mapping in the playbook corpus raises top-1 accuracy from 0.317 to 0.850 and top-3 accuracy from 0.583 to 0.933, a 2.7-fold improvement in first-attempt mapping. This result is intuitive because incident narratives rarely share vocabulary with playbook titles, whereas the full corpus captures the operational vocabulary in which incidents are actually described. The residual top-1 error of 15% in the grounded configuration is concentrated in the deliberately ambiguous queries, which supports the framework decision to present retrieval results to the agentic layer as ranked candidates with evidence, rather than as a single authoritative answer, and to expose the retrieval trace to the audit layer [12,16].

6.4. Experiment 3: Governance-Gated Orchestration (Layers 4 and 5)

The third experiment is the centerpiece of the validation: a discrete-event simulation of 2000 incidents that compares three SOC operating models under Assumptions 3–5. In the manual model, analysts perform triage (median 18 min) and full incident handling (median 12 min for low-impact and 45 min for high-impact incidents). In the narrow-AI model, machine-learning pre-triage reduces triage to a median of 6.5 min and handling to medians of 7 and 30 min, respectively, consistent with the Level-1 maturity studies of Section 4.9 [7,18,29]. In the agentic model, Layers 2–4 complete triage, grounding, and reasoning in a median of 2 min; the governance gate then auto-executes low-risk actions (median 3.5 min including audit logging) and escalates the remainder to an analyst who reviews a prepared evidence pack (median 12 min). The default governance threshold is 0.50. Table 8 summarizes the comparison, and Figure 8 shows mean times and behavior under increasing load.

Walking through Table 8, the governed agentic model reduces mean time to respond from 59.5 min (manual) and 23.4 min (narrow-AI) to 8.8 min, a 6.8-fold improvement over the manual baseline, while reducing analyst touches per incident from 3.50 to 0.32. Under the default threshold, 67.9% of incidents complete on the fully automated low-risk path. The load-scaling results in Figure 8b are, in our view, the more consequential finding. As the arrival rate rises from 6 to 26 incidents per hour, the manual model saturates once demand exceeds analyst capacity: mean response time grows from 44.4 min to over 1655 min. The narrow-AI model postpones but does not remove this saturation, degrading sharply beyond 22 incidents per hour (256.0 min at 26 per hour). The agentic model

remains essentially flat (8.5–8.6 min) across the entire range because the majority of incidents never consume analyst capacity. This result is intuitive because queueing delay is governed by analyst utilization, and only the agentic model structurally reduces the arrival rate at the human queue; it is precisely the telemetry-scale failure mode that the cloud SOC literature identifies [5,7–10], reproduced and quantified in simulation.

Table 8. Comparison of the three SOC operating models at the baseline load of 12 incidents per hour (2000 incidents, 6 analysts, governance threshold 0.50).

Metric	Manual SOC	Narrow-AI Assisted	Agentic + Governance
Mean time to triage (min)	20.1	7.1	2.1
Mean time to respond (min)	59.5	23.4	8.8
90th-percentile time to respond (min)	101.8	44.3	16.5
Analyst touches per incident	3.50	2.50	0.32
Actions auto-executed	0.0%	0.0%	67.9%
Mean queue wait (min)	15.2	0.9	0.0

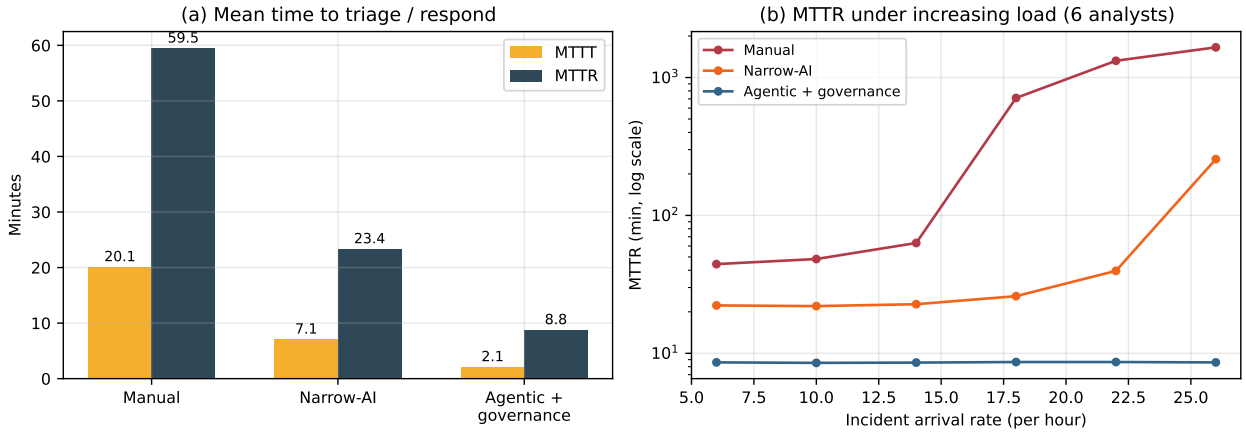


Figure 8. Orchestration results: (**a**) mean time to triage and respond per operating model; (**b**) mean time to respond under increasing incident arrival rates (log scale). The manual model saturates beyond approximately 14 incidents per hour and the narrow-AI model beyond approximately 22, whereas the governed agentic model remains flat at roughly 8.6 min.

Table 9 and Figure 9 quantify what the literature discusses qualitatively as bounded autonomy [6,9,11]. Below a threshold of 0.40, essentially no high-impact action is auto-executed ($\leq$0.48%), at the cost of escalating more than a third of all incidents. At the default threshold of 0.50, the system auto-executes 67.9% of actions while only 1.29% of high-impact actions bypass human approval. Beyond a threshold of approximately 0.6, however, the curve turns sharply: at 0.70, 16.32% of high-impact actions are auto-executed, and at 0.90 the figure reaches 74.15%. The mean response time gained across this entire range is only 3.3 min (from 9.9 to 6.6 min). This asymmetry is the clearest quantitative argument the validation produces for the framework's governance layer: near-total automation buys very little additional speed while dismantling most of the human-approval boundary, so the rational operating region lies at conservative thresholds where speed benefits are already realized. The threshold is therefore best understood as an organizational risk-appetite parameter, to be set by policy and audited over time, rather than tuned for latency.

Table 9. Sensitivity of the governance gate to the risk threshold (agentic model, 2000 incidents per setting; excerpt).

Threshold	Auto-Executed	Escalated	High-Impact Actions Auto-Executed	Mean Time to Respond (min)
0.30	56.3%	43.8%	0.00%	9.9
0.40	64.2%	35.8%	0.48%	9.2
0.50 (default)	67.9%	32.1%	1.29%	8.8
0.60	70.2%	29.9%	4.20%	8.6
0.70	74.1%	26.0%	16.32%	8.2
0.80	81.2%	18.9%	39.10%	7.6
0.90	92.0%	8.0%	74.15%	6.6

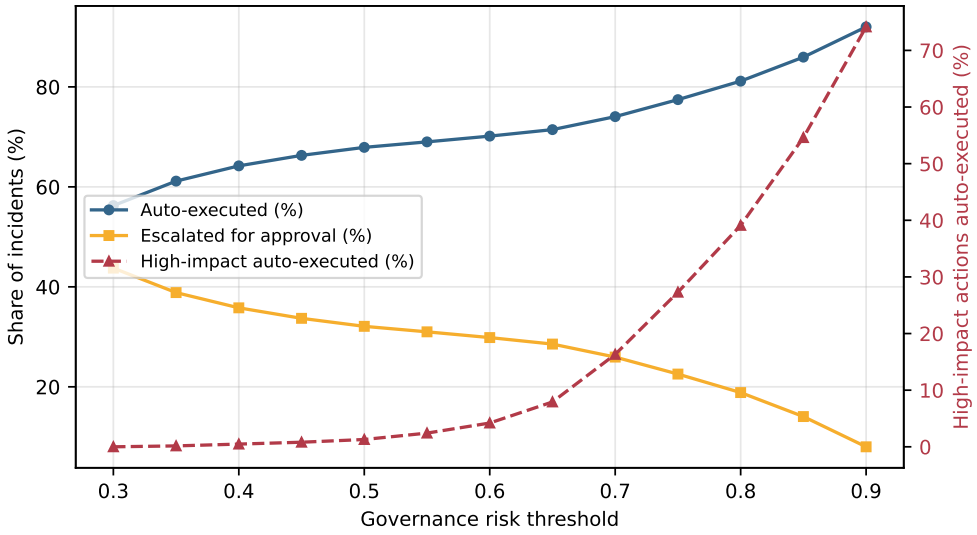


Figure 9. Governance-threshold sensitivity. Raising the threshold increases the auto-executed share but sharply increases the fraction of high-impact actions executed without human approval beyond a threshold of approximately 0.6.

6.5. Experiment 4: Closed-Loop Scenario and Audit Completeness (Layer 6)

The final experiment validates the response-execution and audit layer using the illustrative privilege-escalation scenario of Section 5.5. We perform 1000 Monte Carlo runs of the six-step workflow of Figure 5 (ingestion, triage, retrieval, reasoning, governance decision, execution). Each step logs its evidence subject to the per-step failure probabilities of Assumption 6; 55% of runs cross the governance gate onto the high-risk path and incur a human-approval delay (median 4 min). Table 10 reports the results, and Figure 10 shows per-step logging coverage and the distribution of audit overhead.

Two findings stand out. First, forensic traceability is high but not perfect: 95.5% of runs produce a complete six-step evidence chain, and the mean number of logged steps is 5.95 of 6. Because the reviewed literature identifies forensic preparedness as a first-class requirement rather than an afterthought [6,9], the framework should treat an incomplete chain as a detectable condition that itself triggers escalation, and the per-step coverage in Figure 10a shows exactly where redundant logging would be most valuable: the reasoning step, with the highest single-step failure probability. Second, auditability is inexpensive: mean audit overhead is 1.79% of workflow time, 3.41% at the 95th percentile. This result is intuitive because evidence writes are small relative to the analysis and approval activities they document, and it directly counters the concern that audit requirements would erode the speed advantage established in Experiment 3. The end-to-end times also quantify the

price of governance in absolute terms: the high-risk path averages 327.7 s against 54.3 s on the automated path, a delay of under five minutes that purchases mandatory human review of exactly the actions the literature identifies as consequential.

Table 10. Closed-loop workflow and audit-completeness results (1000 Monte Carlo runs of the privilege-escalation scenario).

Metric	Value
Complete evidence chains (all 6 steps logged)	95.5%
Mean steps logged (of 6)	5.95
Mean audit-logging overhead (% of workflow time)	1.79%
95th-percentile audit overhead	3.41%
Mean end-to-end time, low-risk automated path	54.3 s
Mean end-to-end time, high-risk path incl. approval	327.7 s

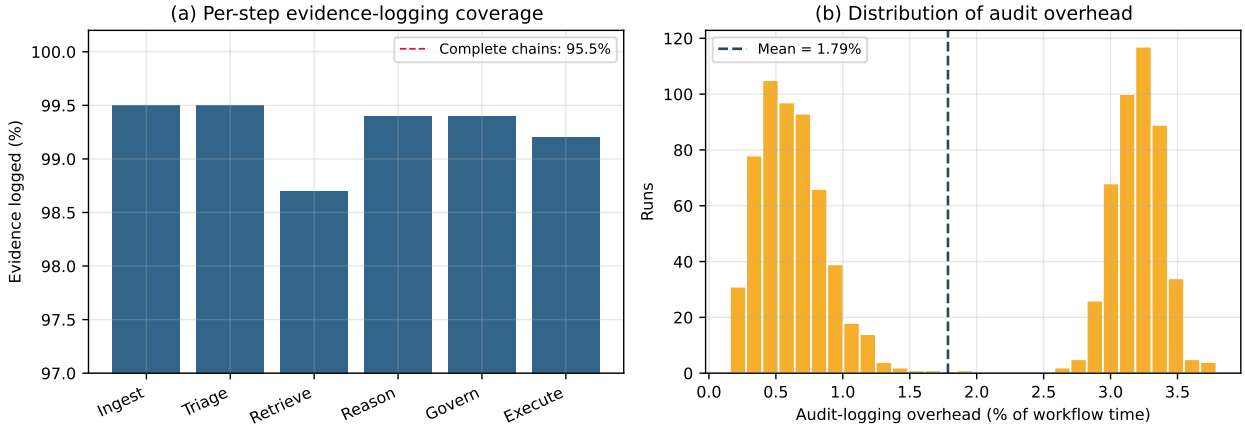


Figure 10. Audit results: (**a**) per-step evidence-logging coverage across 1000 runs; (**b**) distribution of audit-logging overhead as a percentage of total workflow time.

6.6. Threats to Validity

Several validity limitations constrain interpretation. Regarding construct validity, the Random Forest evaluates upstream triage rather than Agentic AI, TF–IDF represents lexical retrieval rather than modern dense RAG, and evidence-chain completeness does not establish cryptographic non-repudiation. Regarding internal validity, synthetic feature distributions, label noise, service times, logging-failure probabilities, and risk-score quality are modeling assumptions rather than measurements from a deployed SOC. Regarding external validity, real cloud telemetry exhibits non-stationarity, adversarial adaptation, provider-specific behavior, and inter-feature dependencies that the generator does not capture. The queueing model also omits LLM inference variation, context exhaustion, repeated reasoning loops, tool failures, and human factors such as fatigue and trust calibration [6,9,19]. Regarding adversarial validity, no experiment evaluates direct or indirect prompt injection, retrieval poisoning, cross-tenant leakage, or malicious tool requests. The security plane therefore remains an architectural requirement until it is implemented and adversarially tested. Finally, the fixed discriminative quality of the Experiment 3 risk score conditions the threshold curve; a weaker score would alter the relationship between speed and unsafe automatic execution. These limitations are consistent with the evaluation's purpose: establishing internal feasibility under declared assumptions rather than forecasting production performance.

6.7. Summary of Validation Findings

Within the specified synthetic scenarios, the four experiments provide component-level feasibility evidence. The triage layer suppresses 59.5–71.8% of alert volume, with a conservative probability gate reducing threat leakage to 4.81% (Experiment 1). Lexical retrieval raises first-attempt playbook mapping from 0.317 to 0.850 (Experiment 2). The modeled governed-agentic configuration reduces mean response time 6.8-fold relative to the modeled manual SOC and remains stable as incident load rises to 26 incidents per hour, while the threshold sweep shows that conservative governance thresholds sacrifice about 3 min relative to near-total automation (Experiment 3). Finally, the modeled workflow achieves 95.5% complete evidence chains at a mean audit overhead of 1.79% (Experiment 4). These conditional results support further evaluation of bounded autonomy but do not demonstrate end-to-end Agentic AI performance, adversarial robustness, or production scalability.

7. Limitations and Future Work

The review has important coverage and reporting limitations. Intermediate counts for the 23-study legacy phase were not retained, so they cannot be retrospectively reconstructed. The Scopus update is reproducible, but 55 of 65 reports sought could not be retrieved; consequently, the 10 included update studies may underrepresent subscription-only research. Web of Science Core Collection was not searched, and ACM coverage was available only insofar as records were indexed by Scopus. Six legacy sources remain preprints, representing 18.2% of the combined 33-study corpus; conclusions that depend on these sources are therefore interpreted cautiously and should be reassessed when peer-reviewed versions become available. These constraints introduce database, retrieval, and publication-maturity bias. The Scopus screening and appraisal records accompany the article as Supplementary Materials. A future update should repeat retrieval with institutional or interlibrary-loan access.

Second, the literature is heterogeneous in publication type, method, validation depth, and technical maturity. This heterogeneity reflects the interdisciplinary and emerging character of the field but limits direct comparison. Some studies report operational implementations, whereas others provide surveys, conceptual arguments, or architectural proposals. The results should therefore be interpreted as a thematic synthesis rather than a quantitative comparison of effectiveness.

Third, the corpus includes preprints as well as peer-reviewed journal and conference papers. The preprints provide timely coverage of rapidly evolving Agentic AI and LLM-supported security research, but they have weaker publication maturity and may change following peer review. The synthesis therefore treats them as emerging evidence rather than equivalent confirmation of operational effectiveness. Future updates should replace preprints with peer-reviewed versions whenever those become available and expand the peer-reviewed evidence base.

Fourth, the component simulations in Section 6 establish internal feasibility under controlled assumptions; they do not validate an end-to-end Agentic AI implementation. The triage experiment evaluates conventional machine learning, the retrieval experiment uses a lexical baseline, and the orchestration and audit experiments are driven by assumed distributions. Empirical testing of LLM latency, context limits, hallucination loops, interoperability, failure management, human trust calibration, and policy-enforcement behavior in production clouds remains future work.

Fifth, the proposed security and trust-enforcement plane has not been implemented or adversarially evaluated. Direct and indirect prompt injection, retrieval poisoning, tool-call manipulation, cross-tenant leakage, and audit-record tampering must be tested in a

representative cloud environment. Future work should compare lexical, dense, and hybrid retrieval; exercise malicious telemetry and poisoned knowledge sources; verify tenant isolation and least-privilege execution; and evaluate tamper-evident logging with appropriate key management. These requirements follow from the broader concerns regarding adversarial robustness, trusted autonomy, accountability, and human oversight in the reviewed literature [6,9–11,14,15,19].

Sixth, no quantitative meta-analysis was conducted because the included sources do not report sufficiently comparable interventions, datasets, outcomes, or effect measures. The synthesis identifies trends and design requirements but cannot provide a pooled estimate of the effectiveness of any specific security technique.

These limitations indicate where research should proceed next. The first research direction is to expand the review corpus through broader databases and wider coverage of peer-reviewed literature as the field develops. The second is to translate conceptual models into working prototypes or reference architectures that can be tested in real cloud incident-response settings. Such studies should address not only detection and orchestration performance but also the alignment of control, explainability, auditability, forensic preparedness, and analyst confidence [6,9,19].

The third research direction is the comparative evaluation of the intelligence models used in SOC workflows. Future work should compare narrow AI, LLM-assisted support, RAG-grounded reasoning, and agentic orchestration in terms of practical performance, error behavior, operational safety, and suitability for different response situations. Such comparisons would clarify the conditions under which semi-autonomous assistance is appropriate, the conditions that require full human control, and how bounded autonomy can be exercised responsibly on cloud platforms.

The fourth research direction concerns policy engineering and governance. Given the recurring emphasis on trust throughout the literature, future work should develop explicit policy models for approval thresholds, escalation logic, evidence retention, and compliance-sensitive orchestration. In particular, research is needed on expressing cloud governance requirements as constraints that intelligent SOC systems can enforce directly, rather than as external obligations applied after the fact.

Finally, human factors deserve greater attention in intelligent security operations. The sustainability of Agentic AI-enabled SOCaaS depends not only on technical capability but also on how analysts perceive, trust, supervise, and work alongside intelligent systems under pressure. Studies are therefore needed on workload effects, trust calibration, the generalizability of explanations, and the quality of human-in-the-loop decisions.

Overall, this study systematizes an emerging research area and provides a conceptual rather than final empirical account. The literature indicates movement toward contextual and orchestrated cloud security operations, but future work must determine whether greater operational intelligence can be accompanied by stronger governance, accountability, adversarial resilience, and human control.

8. Conclusions

Cloud computing security has become increasingly difficult to manage as organizations rely on elastic, API-driven, and distributed infrastructures that demand continuous monitoring, rapid incident response, and strong governance alignment [1,2,4]. At the same time, existing SOC environments continue to face serious operational problems, including alert fatigue, analyst overload, fragmented tools, false positives, and delayed response cycles [5,7–10]. These pressures have created strong motivation for more intelligent and adaptive security operations, particularly through AI-supported triage, retrieval-augmented contextualization, and agentic orchestration [5,10–13,15,16].

This focused systematic review of 33 studies shows that cloud security research is moving from isolated detection assistance toward context-sensitive and orchestration-based models of cyber defense. The Scopus update adds direct evidence on SOC-focused LLM use, multitenant SOCaaS, cloud RAG, and prompt-injection attacks and defenses [20–25,30–33]. The transition remains constrained by fragmented research streams, uneven validation maturity, retrieval bias, and unresolved questions of trust, explainability, governance, adversarial robustness, and forensic preparedness.

The most significant finding is that future cloud security operations are unlikely to be either fully automated or fully manual. Under modern cloud conditions, unrestricted autonomy is increasingly difficult to justify, because response actions can affect critical systems, compliance obligations, and organizational accountability [6,9,19]. The literature instead points toward an integrated operating model in which intelligent systems support triage, contextual reasoning, enrichment, and workflow coordination, while high-risk, ambiguous, or policy-sensitive decisions remain with human analysts.

Based on these findings, the paper proposes a SOCaaS framework that combines multi-source telemetry, automated triage, retrieval-assisted reasoning, bounded agentic orchestration, policy-mediated approval, and auditable response execution. A cross-cutting security plane treats telemetry and retrieved content as untrusted evidence, separates them from system instructions, constrains tools and tenant context, and keeps authorization outside the generative model. This extends the literature's emphasis on trusted autonomy and organizational control [6,9,11,19] to prompt injection, retrieval poisoning, and tool misuse.

The contribution is primarily architectural and conceptual. It provides a structured account of a fragmented literature and a reference design for introducing Agentic AI into cloud-based SOCaaS without treating model output as operational authority. The security plane, tenant boundary, and adversarial controls remain to be implemented and tested in representative cloud deployments.

Under the specified synthetic assumptions, the governed-agentic simulation produces a 6.8-fold lower mean response time than the modeled manual baseline. At the illustrative default threshold, 67.9% of actions are automatically executed, 1.29% of high-impact actions bypass human approval, and 95.5% of workflow runs produce complete six-step evidence chains at a mean audit overhead of 1.79%. These component-level observations do not establish production effectiveness, prompt-injection resistance, or cryptographic non-repudiation.

Overall, the appropriate direction for cloud incident response is policy-aware, adversarially resilient, and auditable intelligent orchestration. Agentic AI is suitable for SOCaaS only when its operation is bounded by transparent reasoning, instruction–data separation, least-privilege tools, deterministic authorization, human control, tenant isolation, and verifiable evidence handling [6,9–11,14,15,19].

Supplementary Materials: The following supporting information can be downloaded at: https://www.mdpi.com/article/10.3390/network6040084/s1. The supplementary Excel workbook contains: Table S1: Scopus search strategy and PRISMA flow counts; Table S2a–d: Raw Scopus exports for the four query families; Table S3: Deduplicated screening records and exclusion reasons; Table S4: Full-text retrieval ledger; Table S5: Quality appraisal of the included Scopus studies; Table S6: Overlap audit of the Phase 1 literature corpus against the Phase 2 Scopus records.

Author Contributions: Conceptualization, A.Y.A. and F.A.A.-Q.; methodology, A.Y.A., F.A.A.-Q. and M.A.; software, M.A.; validation, M.A.; formal analysis, M.A.; investigation, A.Y.A. and F.A.A.-Q.; data curation, M.A.; writing—original draft preparation, A.Y.A., F.A.A.-Q. and M.A.; writing—review and editing, A.Y.A., F.A.A.-Q., A.A. and M.A.; visualization, M.A.; supervision,

A.A.; project administration, A.A. All authors have read and agreed to the published version of the manuscript.

Funding: The authors would like to thank SAUDI ARAMCO Cybersecurity Chair, Imam Abdulrahman Bin Faisal University for funding this project.

Institutional Review Board Statement: Not applicable.

Informed Consent Statement: Not applicable.

Data Availability Statement: The review is based on the published sources cited in the manuscript. The Scopus exports, screening decisions and exclusion reasons, full-text retrieval ledger, quality-appraisal records, and cross-phase overlap audit are provided in the Supplementary Excel workbook (Tables S1–S6). Intermediate selection records for the 23-study legacy phase were not available for retrospective reconstruction. Synthetic data were generated and analyzed for the simulation experiments described in Section 6. The simulation code, generated synthetic datasets, figures, and tabular outputs supporting Section 6 are openly available at https://github.com/usamrf/agentic-socaas-validation (accessed on 7 August 2026) and archived on Zenodo (DOI https://doi.org/10.5281/zenodo.22375531); all experiments are seeded and fully reproducible from the released code.

Conflicts of Interest: The authors declare no conflict of interest.

References

1. Ajvazi, G.; Ajdari, J.; Zenuni, X. AWS and Cloud Data Center Security: Challenges and Mitigation Strategies. In Proceedings of the 48th MIPRO ICT and Electronics Convention (MIPRO), Opatija, Croatia, 2–6 June 2025. [CrossRef]
2. Makoshi, S.M. In-Depth Analysis of Cloud Security: Significance, Service Providers, and NIST Standards. *Authorea* **2025**, *Preprint*. [CrossRef] [PubMed]
3. Farzaan, M.A.M.; Ghanem, M.C.; El-Hajjar, A.; Ratnayake, D.N. AI-Enabled System for Efficient and Effective Cyber Incident Detection and Response in Cloud Environments. *arXiv* **2024**, arXiv:2404.05602.
4. Sapsai, O.; Martseniuk, Y.; Partyka, A.; Harasymchuk, O. Research on automated security incident management in public cloud environments. In *Proceedings of the Cyber Security and Data Protection (CSDP 2025), Lviv, Ukraine, 31 July 2025*; CEUR-WS.org: Bonn, Germany, 2025; Volume 4042, pp. 226–249. Available online: https://ceur-ws.org/Vol-4042/paper18.pdf (accessed on 7 August 2026).
5. Srinivas, S.; Kirk, B.; Zendejas, J.; Espino, M.; Boskovich, M.; Bari, A.; Dajani, K.; Alzahrani, N. AI-Augmented SOC: A Survey of LLMs and Agents for Security Automation. *J. Cybersecur. Priv.* **2025**, *5*, 95. [CrossRef]
6. Mohsin, A.; Janicke, H.; Ibrahim, A.; Sarker, I.H.; Camtepe, S. A Unified Framework for Human–AI Collaboration in Security Operations Centers with Trusted Autonomy. *arXiv* **2025**, arXiv:2505.23397.
7. Ban, T.; Takahashi, T.; Ndichu, S.; Inoue, D. Breaking Alert Fatigue: AI-Assisted SIEM Framework for Effective Incident Response. *Appl. Sci.* **2023**, *13*, 6610. [CrossRef]
8. Saraiva, M.; Mateus-Coelho, N. CyberSoc Framework: A Systematic Review of the State-of-Art. *Procedia Comput. Sci.* **2022**, *204*, 961–972. [CrossRef]
9. Saadallah, M.; Shahim, A.; Khapova, S. Reconciling Tensions in Security Operations Centers: A Paradox Theory Approach. *Big Data Cogn. Comput.* **2025**, *9*, 278. [CrossRef]
10. Mareedu, A. Autonomous Security Operations Centers (SOC): AI Agents for Threat Triage, Response, and Orchestration. *Int. J. Emerg. Res. Eng. Technol.* **2025**, *6*, 63–70. [CrossRef]
11. Ismail; Kurnia, R.; Brata, Z.A.; Nelistiani, G.A.; Heo, S.; Kim, H.; Kim, H. Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence. *Information* **2025**, *16*, 365. [CrossRef]
12. Ismail; Kurnia, R.; Widyatama, F.; Wibawa, I.M.; Brata, Z.A.; Ukasyah; Nelistiani, G.A.; Kim, H. Enhancing Security Operations Center: Wazuh Security Event Response with Retrieval-Augmented-Generation-Driven Copilot. *Sensors* **2025**, *25*, 870. [CrossRef] [PubMed]
13. Papneja, V. The Evolution of Agentic AI in Cybersecurity: From Single LLM Reasoners to Multi-Agent Systems and Autonomous Pipelines. *arXiv* **2025**, arXiv:2512.06659.
14. Afolalu, O.; Tsoeu, M.S. Artificial Intelligence as the Next Frontier in Cyber Defense: Opportunities and Risks. *Electronics* **2025**, *14*, 4853. [CrossRef]
15. Kshetri, N. Transforming cybersecurity with agentic AI to combat emerging cyber threats. *Telecommun. Policy* **2025**, *49*, 102976. [CrossRef]

16. Blefari, F.; Cosentino, C.; Pironti, F.A.; Furfaro, A.; Marozzo, F. CyberRAG: An agentic RAG cyber attack classification and reporting tool. *Future Gener. Comput. Syst.* **2026**, *176*, 108186. [CrossRef]
17. Zhang, J.; Li, S.; Huang, W.; Jing, H.; Zhang, Q.; Xia, X. Design and Computational Modeling of an AI-Based Automated Cybersecurity Incident Response System. *IEEE Access* **2025**, *13*, 154383–154394. . [CrossRef]
18. Chamkar, S.A.; Zaydi, M.; Maleh, Y.; Gherabi, N. Improving Threat Detection in Wazuh Using Machine Learning Techniques. *J. Cybersecur. Priv.* **2025**, *5*, 34. [CrossRef]
19. Falowo, O.; Jacques, B.A. Empirical Study on Automation, AI Trust, and Framework Readiness in Cybersecurity Incident Response. *Algorithms* **2026**, *19*, 62. [CrossRef]
20. Zhu, K.; Yang, X.; Wang, J.; Guo, W.; Wang, W. MELON: Provable Defense Against Indirect Prompt Injection Attacks in AI Agents. In Proceedings of the 42nd International Conference on Machine Learning, Vancouver, BC, Canada, 13–19 July 2025.
21. Wang, Z.; Siu, V.; Ye, Z.; Shi, T.; Nie, Y.; Zhao, X.; Wang, C.; Guo, W.; Song, D. AgentVigil: Automatic Black-Box Red-Teaming for Indirect Prompt Injection against LLM Agents. In *Findings of the Association for Computational Linguistics: EMNLP 2025*; Association for Computational Linguistics: Stroudsburg, PA, USA, 2025; Volume 2025. [CrossRef]
22. Lee, D.; Tiwari, M.; Miranda, B. Prompt Infection: LLM-to-LLM Prompt Injection within Multi-Agent Systems. In *Lecture Notes in Computer Science*; Springer: Berlin/Heidelberg, Germany, 2026. [CrossRef]
23. Debenedetti, E.; Zhang, J.; Balunovic, M.; Beurer-Kellner, L.; Fischer, M.; Tramer, F. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In Proceedings of the Advances in Neural Information Processing Systems, Vancouver, BC, Canada, 10–15 December 2024.
24. Zhang, H.; Huang, J.; Mei, K.; Yao, Y.; Wang, Z.; Zhan, C.; Wang, H.; Zhang, Y. Agent Security Bench: Formalizing and Benchmarking Attacks and Defenses in LLM-Based Agents. In Proceedings of the 13th International Conference on Learning Representations, Singapore, 24–28 April 2025.
25. Zhan, Q.; Fang, R.; Panchal, H.S.; Kang, D. Adaptive Attacks Break Defenses Against Indirect Prompt Injection Attacks on LLM Agents. In *Findings of the Association for Computational Linguistics: NAACL 2025, Albuquerque, NM, USA, April 2025*; Chiruzzo, L., Ritter, A., Wang, L., Eds.; Association for Computational Linguistics: Stroudsburg, PA, USA, 2025; pp. 7116–7132. [CrossRef]
26. León, A.; Perdices, D.; García-Dorado, J.L.; Ramos, J.; Aracil, J. An expert-aware Markovian system for end-user proactive troubleshooting in the Network and Security Operations Center. *Expert Syst. Appl.* **2025**, *276*, 127072. [CrossRef]
27. Wichary, T.; Mongay Batalla, J.; Mavromoustakis, C.X.; Żurek, J.; Mastorakis, G. Network Slicing Security Controls and Assurance for Verticals. *Electronics* **2022**, *11*, 222. [CrossRef]
28. Arfaoui, B.; Mrabet, H.; Jemai, A. SOCaaS-IoT: A Security Operations Center as a Service Approach for IoT Applications Using Open-Source SIEM. In Proceedings of the International Conference on Advanced Communication Technologies and Networking (CommNet), Rabat, Morocco, 11–13 December 2023. [CrossRef]
29. Zuo, F.; Rhee, J.; Choe, Y.R.; Fu, C.; Qu, X. Few-Shot Learning-Based Cyber Incident Detection with Augmented Context Intelligence. *arXiv* **2025**, arXiv:2506.16626. [CrossRef]
30. Adediran, G.; Awuson-David, K.; Ahmed, Y. Retrieval-Augmented Large Language Model for AWS Cloud Threat Detection and Modelling: CloudTrail MITRE ATT&CK Mapping. *Comput. Mater. Contin.* **2026**, *87*, 100. [CrossRef]
31. Rieger, M.; Shah, A.; Alam, A.; Hossain, M.J. Possibilities and limitations of using large language models for alert classification and prioritisation in security operations centers. *Expert Syst. Appl.* **2026**, *331*, 133194. [CrossRef]
32. Habibzadeh, A.; Feyzi, F.; Atani, R.E. Large Language Models for Security Operations Centers: A Comprehensive Survey. *J. Electr. Comput. Eng.* **2026**, *2026*, 3383674. [CrossRef]
33. Gabrisova, I.; Koman, G. Multitenant Cybersecurity Operations Center Designed as an Open Cloud Service with Machine Learning Elements. In *Proceedings of the 38th Conference of Open Innovations Association (FRUCT)*; FRUCT Oy: Helsinki, Finland, 2025; pp. 58–63. [CrossRef]

Disclaimer/Publisher's Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.